MCP Security Audit Report

AgentSign

figma-console-mcp

20 March 2026

Report ID: MCPS-MMYYWI4J

Executive Summary

FAIL

Risk Score

100/100

46	14	194	4
CRITICAL	HIGH	MEDIUM	LOW

SCAN SCOPE	LANGUAGES	MCPS SDK
76 files 60,343 lines	**json (9), javascript (3), typescript (64)**	**Not Found**

Risk Comparison: WITHOUT MCPS vs WITH MCPS

CURRENT EXPOSURE			WITH MCPS PROTECTION	
MCP-01	**Rug Pulls** Vulnerable pattern detected, no mitigation	🔴	**MITIGATED** Passport identity binding — tools are tied to verified agent identity `createPassport(), signPassport()`	🟢
MCP-03	**Privilege Escalation via Tool Composition** Vulnerable pattern detected, no mitigation	🔴	**MITIGATED** Tool integrity signing — each tool definition is cryptographically signed `signTool(), verifyTool()`	🟢
MCP-04	**Cross-Server Request Forgery** Vulnerable pattern detected, no mitigation	🔴	**MITIGATED** Signed tool definitions prevent tampering during cross-server calls `signTool(), tool_hash`	🟢
MCP-06	**Indirect Prompt Injection via MCP** MCPS mitigation detected	🟢	**MITIGATED** Signed message envelopes — all MCP messages carry cryptographic signatures `signMessage(), verifyMessage()`	🟢
MCP-07	**Resource Exhaustion & DoS** MCPS mitigation detected	🟢	**MITIGATED** Passport verification middleware — all requests require valid signed identity `secureMCP(), verifyPassport()`	🟢
MCP-08	**Insufficient Logging & Audit** MCPS mitigation detected	🟢	**MITIGATED** Signed audit trail — every message exchange is logged with cryptographic proof `auditLog(), onAudit()`	🟢
MCP-09	**Insecure MCP-to-MCP Communication** MCPS mitigation detected	🟢	**MITIGATED** Origin binding — passports encode allowed origins, verified on each request `validateOrigin(), passport.origin`	🟢
MCP-10	**Context Window Pollution** MCPS mitigation detected	🟢	**MITIGATED** Envelope isolation — signed message boundaries prevent context pollution `signMessage(), envelope`	🟢

Risk Reduction

100 --> 100

OWASP MCP Top 10 Compliance

Coverage: 5/8 risks mitigated by MCPS

ID	Risk	Status	Current State	With MCPS
MCP-01	Rug Pulls	FAIL	Vulnerable pattern detected, no mitigation	Passport identity binding — tools are tied to verified agent identity
MCP-02	Tool Poisoning	N/A	Not applicable to code-level analysis	N/A — requires LLM-level defense
MCP-03	Privilege Escalation via Tool Composition	FAIL	Vulnerable pattern detected, no mitigation	Tool integrity signing — each tool definition is cryptographically signed
MCP-04	Cross-Server Request Forgery	FAIL	Vulnerable pattern detected, no mitigation	Signed tool definitions prevent tampering during cross-server calls
MCP-05	Sampling Manipulation	N/A	Not applicable to code-level analysis	N/A — requires client-level defense
MCP-06	Indirect Prompt Injection via MCP	PASS	MCPS mitigation detected	Signed message envelopes — all MCP messages carry cryptographic signatures
MCP-07	Resource Exhaustion & DoS	PASS	MCPS mitigation detected	Passport verification middleware — all requests require valid signed identity
MCP-08	Insufficient Logging & Audit	PASS	MCPS mitigation detected	Signed audit trail — every message exchange is logged with cryptographic proof
MCP-09	Insecure MCP-to-MCP Communication	PASS	MCPS mitigation detected	Origin binding — passports encode allowed origins, verified on each request
MCP-10	Context Window Pollution	PASS	MCPS mitigation detected	Envelope isolation — signed message boundaries prevent context pollution

Quick Fix `npm install mcp-secure`

Add MCPS to your MCP server to automatically mitigate the risks marked FAIL above.

OWASP Agentic AI Top 10 Coverage

12 rules checked | 258 findings

Rule	OWASP	MITRE	STRIDE	Severity	Findings	Status
AS-001	AA-03	T1059	Elevation of Privilege	CRITICAL	43	●
AS-002	AA-05	T1552	Information Disclosure	HIGH	10	●
AS-003	AA-04	T1078	Elevation of Privilege	MEDIUM	147	●
AS-004	AA-02	T1190	Tampering	HIGH	3	●
AS-005	AA-02	T1055	Tampering	CRITICAL	3	●
AS-006	AA-09	T1610	Elevation of Privilege	HIGH	1	●
AS-007	AA-06	T1195	Tampering	LOW	4	●
AS-008	AA-01	T1548	Elevation of Privilege	HIGH	0	●
AS-009	AA-07	T1059.007	Tampering	MEDIUM	13	●
AS-010	AA-08	T1562.002	Repudiation	MEDIUM	34	●
AS-011	AA-10	T1041	Information Disclosure	HIGH	0	●
AS-012	MCP-07	T1078.004	Spoofing	HIGH	0	●

Detailed Findings

#1 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:21`

Dangerous execution: (function() {

```
    19 | // server. This enables console monitoring without CDP.
    20 | // ==========================================================================
>   21 | (function() {
    22 |   var levels = ['log', 'info', 'warn', 'error', 'debug'];…
    23 |   var originals = {};
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#2 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:40`

Dangerous execution: (function(level) {

```
    38 |
    39 |   for (var i = 0; i < levels.length; i++) {
>   40 |     (function(level) {
    41 |       console[level] = function() {
    42 |         // Call the original so output still appears in Figma DevTools
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#3 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:41`

Dangerous execution: console[level] = function() {

```
    39 |   for (var i = 0; i < levels.length; i++) {
    40 |     (function(level) {
>   41 |       console[level] = function() {
    42 |         // Call the original so output still appears in Figma DevTools
    43 |         originals[level].apply(console, arguments);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#4 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:208`

Dangerous execution: (async function() {

```
   206 |     // Re-send variables data to the fresh UI — the original send went to the
   207 |     // bootloader which discarded it. The fresh UI needs it to show "ready" status.
>  208 |     (async function() {
   209 |       try {…
   210 |         var variables = await figma.variables.getLocalVariablesAsync();
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#5 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:218`

Dangerous execution: variables: variables.map(function(v) { return {

```
   216 |             timestamp: Date.now(),
   217 |             fileKey: figma.fileKey || null,
>  218 |             variables: variables.map(function(v) { return {
   219 |               id: v.id, name: v.name, key: v.key, resolvedType: v.resolvedType,
   220 |               valuesByMode: v.valuesByMode, variableCollectionId: v.variableCollectionId,
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#6 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:223`

Dangerous execution: variableCollections: collections.map(function(c) { return {

```
   221 |               scopes: v.scopes, description: v.description, hiddenFromPublishing:
v.hiddenFromPublishing
   222 |             }; }),
>  223 |             variableCollections: collections.map(function(c) { return {
   224 |               id: c.id, name: c.name, key: c.key, modes: c.modes,
   225 |               defaultModeId: c.defaultModeId, variableIds: c.variableIds
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#7 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:262`

Dangerous execution: var wrappedCode = "(async function() {\n" + msg.code + "\n})()";

```
   260 |       // Wrap user code in an async IIFE that returns a Promise
   261 |       // This allows async/await in user code while using eval
>  262 |       var wrappedCode = "(async function() {\n" + msg.code + "\n})()";
   263 |
   264 |       console.log('Ø<ß  [Desktop Bridge] Wrapped code for eval');
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#8 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:268`

Dangerous execution: var timeoutPromise = new Promise(function(_, reject) {

```
   266 |       // Execute with timeout
   267 |       var timeoutMs = msg.timeout || 5000;
>  268 |       var timeoutPromise = new Promise(function(_, reject) {
   269 |         setTimeout(function() {…
   270 |           reject(new Error('Execution timed out after ' + timeoutMs + 'ms'));
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#9 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:269`

Dangerous execution: setTimeout(function() {

```
   267 |       var timeoutMs = msg.timeout || 5000;
   268 |       var timeoutPromise = new Promise(function(_, reject) {
>  269 |         setTimeout(function() {
   270 |           reject(new Error('Execution timed out after ' + timeoutMs + 'ms'));
   271 |         }, timeoutMs);
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#10 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:277`

Dangerous execution: codePromise = eval(wrappedCode);

```
   275 |       try {
   276 |         // eval returns the Promise from the async IIFE
>  277 |         codePromise = eval(wrappedCode);
   278 |       } catch (syntaxError) {
   279 |         // Log the actual syntax error message
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#11 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:722`

Dangerous execution: var currentMode = collection.modes.find(function(m) { return m.modeId === msg.mo

```
   720 |
   721 |       // Find the current mode name
>  722 |       var currentMode = collection.modes.find(function(m) { return m.modeId === msg.modeId; });
   723 |       if (!currentMode) {…
   724 |         throw new Error('Mode not found: ' + msg.modeId);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#12 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:919`

Dangerous execution: node.children.forEach(function(child) {

```
   917 |         // Parse variant properties from children names — skip unresolvable slot sublayers
   918 |         if (node.children) {
>  919 |           node.children.forEach(function(child) {
   920 |             try {
   921 |               if (child.type === 'COMPONENT') {
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#13 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:924`

Dangerous execution: var parts = child.name.split(',').map(function(p) { return p.trim(); });

```
   922 |                 // Parse variant name (e.g., "Size=md, State=default")
   923 |                 var variantProps = {};
>  924 |                 var parts = child.name.split(',').map(function(p) { return p.trim(); });
   925 |                 parts.forEach(function(part) {
   926 |                   var kv = part.split('=');
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#14 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:925`

Dangerous execution: parts.forEach(function(part) {

```
   923 |                 var variantProps = {};
   924 |                 var parts = child.name.split(',').map(function(p) { return p.trim(); });
>  925 |                 parts.forEach(function(part) {
   926 |                   var kv = part.split('=');
   927 |                   if (kv.length === 2) {
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#15 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:976`

Dangerous execution: properties: node.componentPropertyDefinitions ? Object.keys(node.componentProper

```
   974 |           variants: variants,
   975 |           defaultVariant: variants.length > 0 ? variants[0] : null,
 >  976 |           properties: node.componentPropertyDefinitions ?
Object.keys(node.componentPropertyDefinitions).map(function(propName) {
   977 |             var propDef = node.componentPropertyDefinitions[propName];…
   978 |             return {
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#16 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:1002`

Dangerous execution: node.children.forEach(function(child) {

```
  1000 |         // Recurse into children — skip unresolvable slot sublayers
  1001 |         if (node.children) {
> 1002 |           node.children.forEach(function(child) {
  1003 |             try { findComponents(child); } catch (e) { /* slot sublayer — skip */ }
  1004 |           });
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#17 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:1028`

Dangerous execution: batchPages.forEach(function(page) {

```
  1026 |
  1027 |         // Process this batch of pages
> 1028 |         batchPages.forEach(function(page) {
  1029 |           findComponents(page);
  1030 |         });
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#18 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:1039`

Dangerous execution: await new Promise(function(resolve) { setTimeout(resolve, 0); });

```
  1037 |         // Yield to event loop between batches to prevent UI freeze and allow cancellation
  1038 |         if (batchEnd < totalPages) {
> 1039 |           await new Promise(function(resolve) { setTimeout(resolve, 0); });
  1040 |         }…
  1041 |       }
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#19 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:1518`

Dangerous execution: var processedFills = msg.fills.map(function(fill) {

```
  1516 |
  1517 |       // Process fills - convert hex colors if needed
> 1518 |       var processedFills = msg.fills.map(function(fill) {
  1519 |         if (fill.type === 'SOLID' && typeof fill.color === 'string') {
  1520 |           // Convert hex to RGB
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#20 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:1629`

Dangerous execution: var processedStrokes = msg.strokes.map(function(stroke) {

```
  1627 |
  1628 |       // Process strokes - convert hex colors if needed
> 1629 |       var processedStrokes = msg.strokes.map(function(stroke) {
  1630 |         if (stroke.type === 'SOLID' && typeof stroke.color === 'string') {
  1631 |           var rgb = hexToFigmaRGB(stroke.color);
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#21 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:1969`

Dangerous execution: var processedFills = props.fills.map(function(fill) {

```
  1967 |       // Apply fills if specified
  1968 |       if (props.fills) {
> 1969 |         var processedFills = props.fills.map(function(fill) {
  1970 |           if (fill.type === 'SOLID' && typeof fill.color === 'string') {
  1971 |             var rgb = hexToFigmaRGB(fill.color);
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#22 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:2129`

Dangerous execution: .catch(function() { /* non-critical */ });

```
  2127 |   else if (msg.type === 'STORE_CLOUD_CONFIG') {
  2128 |     figma.clientStorage.setAsync('cloudConfig', { code: msg.code, timestamp: Date.now() })
> 2129 |       .catch(function() { /* non-critical */ });
  2130 |   }…
  2131 |
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#23 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:2145`

Dangerous execution: setTimeout(function() {

```
  2143 |       });
  2144 |       // Short delay to let the response message be sent before reload
> 2145 |       setTimeout(function() {
  2146 |         figma.showUI(__html__, { width: 140, height: 50, visible: true, themeColors: true });
  2147 |       }, 100);
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#24 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:2236`

Dangerous execution: currentProperties: Object.keys(updatedProps).reduce(function(acc, key) {

```
  2234 |           componentId: mainComponent ? mainComponent.id : null,
  2235 |           propertiesSet: Object.keys(propsToSet),
> 2236 |           currentProperties: Object.keys(updatedProps).reduce(function(acc, key) {
  2237 |             acc[key] = {
  2238 |               type: updatedProps[key].type,
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#25 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:2793`

Dangerous execution: figma.loadAllPagesAsync().then(function() {

```
  2791 | // Requires figma.loadAllPagesAsync() in dynamic-page mode before registering.
  2792 | // ==============================================================================
> 2793 | figma.loadAllPagesAsync().then(function() {
  2794 |   figma.on('documentchange', function(event) {…
  2795 |     var hasStyleChanges = false;
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#26 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:2794`

Dangerous execution: figma.on('documentchange', function(event) {

```
  2792 | // ==============================================================================
  2793 | figma.loadAllPagesAsync().then(function() {
> 2794 |   figma.on('documentchange', function(event) {
  2795 |     var hasStyleChanges = false;
  2796 |     var hasNodeChanges = false;
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#27 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:2825`

Dangerous execution: figma.on('selectionchange', function() {

```
  2823 |   });
  2824 |   // Selection change listener — tracks what the user has selected in Figma
> 2825 |   figma.on('selectionchange', function() {
  2826 |     var selection = figma.currentPage.selection;
  2827 |     var selectedNodes = [];
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#28 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:2856`

Dangerous execution: figma.on('currentpagechange', function() {

```
  2854 |
  2855 |   // Page change listener — tracks which page the user is viewing
> 2856 |   figma.on('currentpagechange', function() {
  2857 |     figma.ui.postMessage({
  2858 |       type: 'PAGE_CHANGE',
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#29 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`figma-desktop-bridge/code.js:2868`

Dangerous execution: }).catch(function(err) {

```
  2866 |
  2867 |   console.log('Ø<ß  [Desktop Bridge] Document change, selection, and page listeners registered');
> 2868 | }).catch(function(err) {
  2869 |   console.warn('Ø<ß  [Desktop Bridge] Could not register event listeners:', err);…
  2870 | });
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#30 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`figma-desktop-bridge/code.js:266`

High-risk permission pattern: // Execute with timeout

```
   264 |       console.log('Ø<ß  [Desktop Bridge] Wrapped code for eval');
   265 |
>  266 |       // Execute with timeout
   267 |       var timeoutMs = msg.timeout || 5000;
   268 |       var timeoutPromise = new Promise(function(_, reject) {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#31 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`figma-desktop-bridge/code.js:519`

High-risk permission pattern: // DELETE_VARIABLE - Delete a variable

```
   517 |
   518 |   // ============================================================================
>  519 |   // DELETE_VARIABLE - Delete a variable
   520 |   // ============================================================================
   521 |   else if (msg.type === 'DELETE_VARIABLE') {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#32 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`figma-desktop-bridge/code.js:547`

High-risk permission pattern: console.error('Ø<ß [Desktop Bridge] Delete variable error:', error);

```
   545 |
   546 |     } catch (error) {
>  547 |       console.error('Ø<ß  [Desktop Bridge] Delete variable error:', error);
   548 |       figma.ui.postMessage({…
   549 |         type: 'DELETE_VARIABLE_RESULT',
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#33 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`figma-desktop-bridge/code.js:558`

High-risk permission pattern: // DELETE_VARIABLE_COLLECTION - Delete a variable collection

```
   556 |
   557 |   // ==========================================================================
>  558 |   // DELETE_VARIABLE_COLLECTION - Delete a variable collection
   559 |   // ==========================================================================
   560 |   else if (msg.type === 'DELETE_VARIABLE_COLLECTION') {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#34 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`figma-desktop-bridge/code.js:587`

High-risk permission pattern: console.error('Ø<ß [Desktop Bridge] Delete collection error:', error);

```
   585 |
   586 |     } catch (error) {
>  587 |       console.error('Ø<ß  [Desktop Bridge] Delete collection error:', error);
   588 |       figma.ui.postMessage({
   589 |         type: 'DELETE_VARIABLE_COLLECTION_RESULT',
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#35 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`figma-desktop-bridge/code.js:1381`

High-risk permission pattern: // DELETE_COMPONENT_PROPERTY - Delete a component property

```
  1379 |
  1380 |   // ==========================================================================
> 1381 |   // DELETE_COMPONENT_PROPERTY - Delete a component property
  1382 |   // ==========================================================================
  1383 |   else if (msg.type === 'DELETE_COMPONENT_PROPERTY') {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#36 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`figma-desktop-bridge/code.js:1408`

High-risk permission pattern: console.error('Ø<ß [Desktop Bridge] Delete component property error:', errorMsg);

```
  1406 |     } catch (error) {
  1407 |       var errorMsg = error && error.message ? error.message : String(error);
> 1408 |       console.error('Ø<ß [Desktop Bridge] Delete component property error:', errorMsg);
  1409 |       figma.ui.postMessage({…
  1410 |         type: 'DELETE_COMPONENT_PROPERTY_RESULT',
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#37 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`figma-desktop-bridge/code.js:1786`

High-risk permission pattern: // DELETE_NODE - Delete a node

```
  1784 |
  1785 |   // ==========================================================================
> 1786 |   // DELETE_NODE - Delete a node
  1787 |   // ==========================================================================
  1788 |   else if (msg.type === 'DELETE_NODE') {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#38 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`figma-desktop-bridge/code.js:1812`

High-risk permission pattern: console.error('Ø<ß [Desktop Bridge] Delete node error:', errorMsg);

```
  1810 |     } catch (error) {
  1811 |       var errorMsg = error && error.message ? error.message : String(error);
> 1812 |       console.error('Ø<ß [Desktop Bridge] Delete node error:', errorMsg);
  1813 |       figma.ui.postMessage({
  1814 |         type: 'DELETE_NODE_RESULT',
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#39 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`figma-desktop-bridge/code.js:2732`

High-risk permission pattern: // ---- Execute walk ----

```
  2730 |       }
  2731 |
> 2732 |       // ---- Execute walk ----
  2733 |       walkNode(rootNode, 0);…
  2734 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#40 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`figma-desktop-bridge/code.js:2803`

High-risk permission pattern: } else if (change.type === 'CREATE' || change.type === 'DELETE' || change.type =

```
  2801 |       if (change.type === 'STYLE_CREATE' || change.type === 'STYLE_DELETE' || change.type ===
'STYLE_PROPERTY_CHANGE') {
  2802 |         hasStyleChanges = true;
> 2803 |       } else if (change.type === 'CREATE' || change.type === 'DELETE' || change.type ===
'PROPERTY_CHANGE') {
  2804 |         hasNodeChanges = true;
  2805 |         if (change.id && changedNodeIds.length < 50) {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#41 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`jest.config.cjs:1`

No logging, auditing, or monitoring detected

```
>    1 | /** @type {import('jest').Config} */
     2 | module.exports = {
     3 |   preset: 'ts-jest',
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#42 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/apps/design-system-dashboard/scoring/accessibility.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Accessibility Scorer (weight: 0.15)
     3 |  *
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#43 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/apps/design-system-dashboard/scoring/component-metadata.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Component Metadata Scorer (weight: 0.20)…
     3 |  *
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#44 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/apps/design-system-dashboard/scoring/consistency.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Consistency Scorer (weight: 0.15)
     3 |  *
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#45 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/apps/design-system-dashboard/scoring/coverage.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Coverage Scorer (weight: 0.10)
     3 |  *
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#46 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/apps/design-system-dashboard/scoring/engine.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Design System Health Dashboard — Scoring Engine…
     3 |  *
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#47 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/apps/design-system-dashboard/scoring/naming-semantics.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Naming & Semantics Scorer (weight: 0.20)
     3 |  *
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#48 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/apps/design-system-dashboard/scoring/token-architecture.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Token Architecture Scorer (weight: 0.20)
     3 |  *
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#49 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

`src/apps/design-system-dashboard/server.ts:91`

Known injection pattern detected

```
     89 | ™™™{
     90 | ™™™—G— S¢ 'FW‡B"  2 6öç7BÀ
>    91 | ™™™—FW‡C¢  FW6–vâ 7—7FVÓ¢ G¶f–ÆTæ ÖWÒâ †V ÇFƒ¢ G·66÷&VBæ÷fW& ÆÇÒó    r G·66÷&VBç7F GW7Òâ
${categorySummaries}.${unavailableNote} The dashboard UI is now showing detailed results.`,
     92 | ™™™},
     93 | ™™™•ÒÀ
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#50 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/apps/design-system-dashboard/ui/mcp-app.ts:163`

High-risk permission pattern: expandedCategories.delete(id);

```
  161 | ™–6öç7B –B Ò 6 DVÂæF F 6WBæ–C°
  162 | ™––b †W‡  æFVD6 FVv÷&–W2æ† 2†–B’’ °
> 163 | ™™expandedCategories.delete(id);
  164 | ™™catEl.classList.remove("expanded");…
  165 | ™–Ò VÇ6R °
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#51 AS-009 -- OUTPUT HANDLING

MEDIUM

OWASP: AA-07 | MITRE: T1059.007 | STRIDE: Tampering

Unsafe output handling that could enable XSS through agent-generated content

`src/apps/design-system-dashboard/ui/mcp-app.ts:116`

Unsafe output handling: appContainer.innerHTML = ` Connection failed: ${esc(String

```
  114 | –Ò•
  115 | ’æ6 F6,,†W'"’ Óâ °
> 116 | ™appContainer.innerHTML = `<div class="error-msg">Connection failed: ${esc(String(err))}</div>`;
  117 | –Ó”°
  118 |
```

Remediation:

1. Always use textContent instead of innerHTML for agent-generated text. 2. Use DOMPurify or sanitize-html before rendering any HTML from agents. 3. Implement Content Security Policy (CSP) headers. 4. Use React's default escaping (avoid dangerouslySetInnerHTML). 5. Validate and escape all agent output at the rendering boundary.

#52 AS-009 -- OUTPUT HANDLING

MEDIUM

OWASP: AA-07 | MITRE: T1059.007 | STRIDE: Tampering

Unsafe output handling that could enable XSS through agent-generated content

`src/apps/design-system-dashboard/ui/mcp-app.ts:132`

Unsafe output handling: appContainer.innerHTML = `<div class="error-msg">${esc(data.error)}</div>`;

```
  130 | ™™const data = JSON.parse(textBlock.text as string);
  131 | ™™if (data.error) {
> 132 | ™™–   6öçF –æW"æ–ææW$…DÔÂ Ò  ÆF–b 6Æ 73Ò&W'&÷"Ö×6r#âG¶W62†F F æW'&÷"–ÓÂöF–cæ °
  133 | ™™–&WGW&ã°
  134 | ™™}
```

Remediation:

1. Always use textContent instead of innerHTML for agent-generated text. 2. Use DOMPurify or sanitize-html before rendering any HTML from agents. 3. Implement Content Security Policy (CSP) headers. 4. Use React's default escaping (avoid dangerouslySetInnerHTML). 5. Validate and escape all agent output at the rendering boundary.

#53 AS-009 -- OUTPUT HANDLING

MEDIUM

OWASP: AA-07 | MITRE: T1059.007 | STRIDE: Tampering

Unsafe output handling that could enable XSS through agent-generated content

`src/apps/design-system-dashboard/ui/mcp-app.ts:139`

Unsafe output handling: appContainer.innerHTML =

```
  137 | ™™–&VæFW",”°
  138 | ™™} else {
> 139 | ™™–   6öçF –æW"æ–ææW$…DÔÂ Ð
  140 | ™™™'<div class="empty">No design system data found.</div>';
  141 | ™™}
```

Remediation:
1. Always use textContent instead of innerHTML for agent-generated text. 2. Use DOMPurify or sanitize-html before rendering any HTML from agents. 3. Implement Content Security Policy (CSP) headers. 4. Use React's default escaping (avoid dangerouslySetInnerHTML). 5. Validate and escape all agent output at the rendering boundary.

#54 AS-009 -- OUTPUT HANDLING

MEDIUM

OWASP: AA-07 | MITRE: T1059.007 | STRIDE: Tampering

Unsafe output handling that could enable XSS through agent-generated content

`src/apps/design-system-dashboard/ui/mcp-app.ts:145`

Unsafe output handling: appContainer.innerHTML = ` Failed to load dashboard: ${esc

```
   143 | ™}
   144 | —Ó 6 F6, †W'"’ °
>  145 | ™appContainer.innerHTML = `<div class="error-msg">Failed to load dashboard: ${esc(String(err))}</
div>`;
   146 | —ØP
   147 | }
```

Remediation:
1. Always use textContent instead of innerHTML for agent-generated text. 2. Use DOMPurify or sanitize-html before rendering any HTML from agents. 3. Implement Content Security Policy (CSP) headers. 4. Use React's default escaping (avoid dangerouslySetInnerHTML). 5. Validate and escape all agent output at the rendering boundary.

#55 AS-009 -- OUTPUT HANDLING

MEDIUM

OWASP: AA-07 | MITRE: T1059.007 | STRIDE: Tampering

Unsafe output handling that could enable XSS through agent-generated content

`src/apps/design-system-dashboard/ui/mcp-app.ts:191`

Unsafe output handling: appContainer.innerHTML =

```
   189 | function render(): void {
   190 | ––b , F 6†&ö &DF F ’ °
>  191 | ™appContainer.innerHTML =
   192 | ™’sÆF—b 6Æ 73Ò&Æö F–ær#ä æ Ç—¦–ær FW6–vâ 7—7FVÒâãâÂöF—câs°
   193 | ™return;
```

Remediation:
1. Always use textContent instead of innerHTML for agent-generated text. 2. Use DOMPurify or sanitize-html before rendering any HTML from agents. 3. Implement Content Security Policy (CSP) headers. 4. Use React's default escaping (avoid dangerouslySetInnerHTML). 5. Validate and escape all agent output at the rendering boundary.

#56 AS-009 -- OUTPUT HANDLING

MEDIUM

OWASP: AA-07 | MITRE: T1059.007 | STRIDE: Tampering

Unsafe output handling that could enable XSS through agent-generated content

`src/apps/design-system-dashboard/ui/mcp-app.ts:207`

Unsafe output handling: appContainer.innerHTML =

```
   205 |
   206 | ––b †6 FVv÷&–W2æÆVæwF, ÓÓÒ  ’ °
>  207 | ™appContainer.innerHTML =
   208 | ™’sÆF—b 6Æ 73Ò&V× G’#äæò FW6–vâ 7—7FVÒ F F  f÷VæBãÂöF—câs°
   209 | ™return;
```

Remediation:
1. Always use textContent instead of innerHTML for agent-generated text. 2. Use DOMPurify or sanitize-html before rendering any HTML from agents. 3. Implement Content Security Policy (CSP) headers. 4. Use React's default escaping (avoid dangerouslySetInnerHTML). 5. Validate and escape all agent output at the rendering boundary.

#57 AS-009 -- OUTPUT HANDLING

MEDIUM

OWASP: AA-07 | MITRE: T1059.007 | STRIDE: Tampering

Unsafe output handling that could enable XSS through agent-generated content

`src/apps/design-system-dashboard/ui/mcp-app.ts:234`

Unsafe output handling: appContainer.innerHTML = `

```
  232 | ™“¢ "#°
  233 |
> 234 | –   6öçF –æW"æ–ææW$…DÔÂ Ò
  235 | ™<div class="header">…
  236 | ™“ÆF—cà
```

Remediation:

1. Always use textContent instead of innerHTML for agent-generated text. 2. Use DOMPurify or sanitize-html before rendering any HTML from agents. 3. Implement Content Security Policy (CSP) headers. 4. Use React's default escaping (avoid dangerouslySetInnerHTML). 5. Validate and escape all agent output at the rendering boundary.

#58 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/apps/token-browser/server.ts:1`

No logging, auditing, or monitoring detected

```
>   1 | /**
    2 |  * Token Browser MCP App - Server Registration
    3 |  *
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#59 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/apps/token-browser/ui/mcp-app.ts:126`

High-risk permission pattern: expandedCollections.delete(id);

```
  124 | ™–6öç7B –B Ò 6öÆÄVÂæF F 6WBæ–C°
  125 | ™––b †W‡  æFVD6öÆÆV7F–öç2æ† 2†–B’’ °
> 126 | ™™expandedCollections.delete(id);
  127 | ™—Ò VÇ6R °
  128 | ™™expandedCollections.add(id);
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#60 AS-009 -- OUTPUT HANDLING

MEDIUM

OWASP: AA-07 | MITRE: T1059.007 | STRIDE: Tampering

Unsafe output handling that could enable XSS through agent-generated content

`src/apps/token-browser/ui/mcp-app.ts:62`

Unsafe output handling: appContainer.innerHTML = ` Connection failed: ${esc(String

```
   60 | —Ò•
   61 | ’æ6 F6,,†W'"’ Óâ °
>  62 | ™appContainer.innerHTML = `<div class="error-msg">Connection failed: ${esc(String(err))}</div>`;
   63 | —Ò“°
   64 |
```

Remediation:
1. Always use textContent instead of innerHTML for agent-generated text. 2. Use DOMPurify or sanitize-html before rendering any HTML from agents. 3. Implement Content Security Policy (CSP) headers. 4. Use React's default escaping (avoid dangerouslySetInnerHTML). 5. Validate and escape all agent output at the rendering boundary.

#61 AS-009 -- OUTPUT HANDLING

MEDIUM

OWASP: AA-07 | MITRE: T1059.007 | STRIDE: Tampering

Unsafe output handling that could enable XSS through agent-generated content

`src/apps/token-browser/ui/mcp-app.ts:78`

Unsafe output handling: appContainer.innerHTML = `<div class="error-msg">${esc(data.error)}</div>`;

```
    76 | ™™const data = JSON.parse(textBlock.text as string);
    77 | ™™if (data.error) {
>   78 | ™™–    6öçF –æW"æ–ææW$…DÔÂ Ò  ÆF—b 6Æ 73Ò&W'&÷"Ö×6r#âG¶W62†F F æW'&÷"—ÓÂöF—cæ °
    79 | ™™—&WGW&ã¸P
    80 | ™™}
```

Remediation:
1. Always use textContent instead of innerHTML for agent-generated text. 2. Use DOMPurify or sanitize-html before rendering any HTML from agents. 3. Implement Content Security Policy (CSP) headers. 4. Use React's default escaping (avoid dangerouslySetInnerHTML). 5. Validate and escape all agent output at the rendering boundary.

#62 AS-009 -- OUTPUT HANDLING

MEDIUM

OWASP: AA-07 | MITRE: T1059.007 | STRIDE: Tampering

Unsafe output handling that could enable XSS through agent-generated content

`src/apps/token-browser/ui/mcp-app.ts:92`

Unsafe output handling: appContainer.innerHTML = ` Failed to load tokens: ${esc(St

```
    90 | ™}
    91 | —Ò 6 F6, †W'"' °
>   92 | ™appContainer.innerHTML = `<div class="error-msg">Failed to load tokens: ${esc(String(err))}</div>`;
    93 | —Ð
    94 | }
```

Remediation:
1. Always use textContent instead of innerHTML for agent-generated text. 2. Use DOMPurify or sanitize-html before rendering any HTML from agents. 3. Implement Content Security Policy (CSP) headers. 4. Use React's default escaping (avoid dangerouslySetInnerHTML). 5. Validate and escape all agent output at the rendering boundary.

#63 AS-009 -- OUTPUT HANDLING

MEDIUM

OWASP: AA-07 | MITRE: T1059.007 | STRIDE: Tampering

Unsafe output handling that could enable XSS through agent-generated content

`src/apps/token-browser/ui/mcp-app.ts:175`

Unsafe output handling: appContainer.innerHTML =

```
   173 | function render(): void {
   174 | ––b , Fö¶VäF F ’ °
>  175 | ™appContainer.innerHTML =
   176 | ™’sÆF—b 6Æ 73Ò&Æö F–ær#äÆö F–ær FW6–vâ Fö¶Vç2ãâãÂöF—câs°
   177 | ™return;
```

Remediation:
1. Always use textContent instead of innerHTML for agent-generated text. 2. Use DOMPurify or sanitize-html before rendering any HTML from agents. 3. Implement Content Security Policy (CSP) headers. 4. Use React's default escaping (avoid dangerouslySetInnerHTML). 5. Validate and escape all agent output at the rendering boundary.

#64 AS-009 -- OUTPUT HANDLING

MEDIUM

OWASP: AA-07 | MITRE: T1059.007 | STRIDE: Tampering

Unsafe output handling that could enable XSS through agent-generated content

`src/apps/token-browser/ui/mcp-app.ts:183`

Unsafe output handling: appContainer.innerHTML = ' No design tokens found. ';

```
  181 |
  182 | ––b ‡f &– &ÆW2æÆVæwF, ÓÓÒ  ’ °
> 183 | ™appContainer.innerHTML = '<div class="empty">No design tokens found.</div>';
  184 | ™return;…
  185 | —Ð
```

Remediation:
1. Always use textContent instead of innerHTML for agent-generated text. 2. Use DOMPurify or sanitize-html before rendering any HTML from agents. 3. Implement Content Security Policy (CSP) headers. 4. Use React's default escaping (avoid dangerouslySetInnerHTML). 5. Validate and escape all agent output at the rendering boundary.

#65 AS-009 -- OUTPUT HANDLING

MEDIUM

OWASP: AA-07 | MITRE: T1059.007 | STRIDE: Tampering

Unsafe output handling that could enable XSS through agent-generated content

`src/apps/token-browser/ui/mcp-app.ts:248`

Unsafe output handling: appContainer.innerHTML = `

```
  246 | ™.join("");
  247 |
> 248 | –   6öçF –æW"æ–ææW$…DÔÂ Ò
  249 | ™<div class="header">
  250 | ™“ÆF—cà
```

Remediation:
1. Always use textContent instead of innerHTML for agent-generated text. 2. Use DOMPurify or sanitize-html before rendering any HTML from agents. 3. Implement Content Security Policy (CSP) headers. 4. Use React's default escaping (avoid dangerouslySetInnerHTML). 5. Validate and escape all agent output at the rendering boundary.

#66 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/apps/token-browser/ui/mcp-app.ts:1`

No logging, auditing, or monitoring detected

```
>   1 | import {
    2 | ”   À
    3 | –   Ç”Fö7VÖVçEF†VÖRÀ
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#67 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/browser/base.ts:1`

No logging, auditing, or monitoring detected

```
>   1 | /**
    2 |  * Browser Manager Interface
    3 |  * Abstract interface for browser automation across different runtimes
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#68 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/browser/cloudflare.ts:135`

High-risk permission pattern: * Execute JavaScript in page context

```
   133 |
   134 | ’ò¢
>  135 | ’ ¢ W†V7WFR ¦ f 67&— B –â   vR 6öçFW‡@
   136 | ’ ¢øP
   137 | – 7–æ2 Wf ÇV FSÅCâ†fã¢ ,’ Óâ B“¢  &öÖ—6SÅCâ °
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#69 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/browser/local.ts:262`

High-risk permission pattern: * Execute JavaScript in page context

```
   260 |
   261 | ’ò¢
>  262 | ’ ¢ W†V7WFR ¦ f 67&— B –â   vR 6öçFW‡@
   263 | ’ ¢ð
   264 | – 7–æ2 Wf ÇV FSÅCâ†fã¢ ,’ Óâ B“¢  &öÖ—6SÅCâ °
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#70 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/browser-manager.ts:142`

High-risk permission pattern: * Execute JavaScript in page context

```
   140 |
   141 | ’ò¢
>  142 | ’ ¢ W†V7WFR ¦ f 67&— B –â   vR 6öçFW‡@
   143 | ’ ¢ð
   144 | – 7–æ2 Wf ÇV FSÅCâ†fã¢ ,’ Óâ B“¢  &öÖ—6SÅCâ °
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#71 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`src/core/cloud-websocket-connector.ts:64`

Dangerous execution: variables: variables.map(function(v) { return { id: v.id, name: v.name, key: v.k

```
    62 |             timestamp: Date.now(),
    63 |             fileMetadata: { fileName: figma.root.name, fileKey: figma.fileKey || null },
>   64 |             variables: variables.map(function(v) { return { id: v.id, name: v.name, key: v.key,
resolvedType: v.resolvedType, valuesByMode: v.valuesByMode, variableCollectionId: v.variableCollectionId,
scopes: v.scopes, description: v.description, hiddenFromPublishing: v.hiddenFromPublishing }; }),
    65 |             variableCollections: collections.map(function(c) { return { id: c.id, name: c.name, key:
c.key, modes: c.modes, defaultModeId: c.defaultModeId, variableIds: c.variableIds }; })…
    66 |           };
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#72 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`src/core/cloud-websocket-connector.ts:65`

Dangerous execution: variableCollections: collections.map(function(c) { return { id: c.id, name: c.na

```
    63 |             fileMetadata: { fileName: figma.root.name, fileKey: figma.fileKey || null },
    64 |             variables: variables.map(function(v) { return { id: v.id, name: v.name, key: v.key,
resolvedType: v.resolvedType, valuesByMode: v.valuesByMode, variableCollectionId: v.variableCollectionId,
scopes: v.scopes, description: v.description, hiddenFromPublishing: v.hiddenFromPublishing }; }),
>   65 |             variableCollections: collections.map(function(c) { return { id: c.id, name: c.name, key:
c.key, modes: c.modes, defaultModeId: c.defaultModeId, variableIds: c.variableIds }; })
    66 |           };
    67 |         } catch (error) {
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#73 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/core/cloud-websocket-connector.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Cloud WebSocket Connector
     3 |  *
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#74 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`src/core/cloud-websocket-relay.ts:39`

Potential secret: possible hardcoded secret

```
    37 |  */
    38 | export function generatePairingCode(): string {
>   39 | –6öç7B 6† '2 Ò t $4DTdt„¤´ÄÔå  %5EUeu…•£#3CScsƒ’s² òò æò  ôòó ô’ 6öægW6–öà
    40 | –ÆWB 6öFR Ò rs˚P
    41 | –6öç7B  '" Ò æWr V–çC„ '& ’ƒb“°
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#75 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/cloud-websocket-relay.ts:150`

High-risk permission pattern: this.pendingRequests.delete(data.id);

```
   148 | ™™const pending = this.pendingRequests.get(data.id)!;
   149 | ™™clearTimeout(pending.timeoutId);
>  150 | ™™this.pendingRequests.delete(data.id);
   151 |
   152 | ™™const body = JSON.stringify(data.error
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#76 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/cloud-websocket-relay.ts:181`

High-risk permission pattern: this.ctx.storage.delete('fileInfo');

```
   179 | – &–f FR † æFÆTF–66öææV7B,“¢ fö–B °
   180 | ™// Clear persisted file info
>  181 | ™this.ctx.storage.delete('fileInfo');
   182 |
   183 | ™// Reject all in-flight commands
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#77 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/cloud-websocket-relay.ts:226`

High-risk permission pattern: this.pendingRequests.delete(id);

```
   224 | ™–6öç7B F–ÖV÷WD–B Ò 6WEF–ÖV÷WB,,’ Óâ °
   225 | ™™if (this.pendingRequests.has(id)) {
>  226 | ™™–F†–2ç VæF–æu&W VW7G2æFVÆWFR†–B“°
   227 | ™™–&W6öÇfR†æWr &W7 öç6R€
   228 | ™™™JSON.stringify({ error: `Command ${method} timed out after ${timeoutMs}ms` }),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#78 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/core/cloud-websocket-relay.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Cloud WebSocket Relay — Durable Object…
     3 |  *
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#79 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/comment-tools.ts:263`

High-risk permission pattern: "Delete a comment from a Figma file by its comment ID. Use figma_get_comments to

```
   261 | –6W'fW"çFööÂ€
   262 | ™"figma_delete_comment",
>  263 | ™"Delete a comment from a Figma file by its comment ID. Use figma_get_comments to find comment IDs
first.",
   264 | ™{
   265 | ™–f–ÆUW&Ã¢
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#80 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/comment-tools.ts:272`

High-risk permission pattern: .describe("The ID of the comment to delete. Get IDs from figma_get_comments."),

```
   270 | ™–6öÖÖVçEö–C¢
   271 | ™™.string()
>  272 | ™™.describe("The ID of the comment to delete. Get IDs from figma_get_comments."),
   273 | ™},
   274 | ™async ({ fileUrl, comment_id }) => {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#81 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/comment-tools.ts:327`

High-risk permission pattern: logger.error({ error }, "Failed to delete comment");

```
  325 | ™—Ò 6 F6, †W'&÷"’ °
  326 | ™™const message = error instanceof Error ? error.message : String(error);
> 327 | ™™logger.error({ error }, "Failed to delete comment");
  328 |…
  329 | ™™return {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#82 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/comment-tools.ts:335`

High-risk permission pattern: message: `Cannot delete comment. ${message}`,

```
  333 | ™™™—FW‡C¢ ¥4ôâç7G&–æv–g’‡°
  334 | ™™™™error: "delete_comment_failed",
> 335 | ™™™™message: `Cannot delete comment. ${message}`,
  336 | ™™™—Ò’À
  337 | ™™™},
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#83 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/core/config.ts:1`

No logging, auditing, or monitoring detected

```
>   1 | /**
    2 |  * Configuration management for Figma Console MCP server
    3 |  */
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#84 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/console-monitor.ts:146`

High-risk permission pattern: this.workers.delete(worker);

```
  144 | ™page.on('workerdestroyed', (worker: any) => {
  145 | ™–ÆövvW"æ–æfò‡² v÷&¶W%W&Ã¢ v÷&¶W"çW&Â,’ ÒÂ uv÷&¶W" FW7G&÷–VBr“°
> 146 | ™—F†—2çv÷&¶W'2æFVÆWFR‡v÷&¶W"“°
  147 | ™});
  148 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#85 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/design-system-manifest.ts:237`

High-risk permission pattern: this.cache.delete(fileKey);

```
  235 | ™if (!entry) return null;
  236 | ™if (!this.isValid(entry)) {
> 237 | ™—F†—2æ6 6†RæFVÆWFR†f–ÆT¶W’“°
  238 | ™—&WGW&â çVÆÃ¸P
  239 | ™}
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#86 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/design-system-manifest.ts:253`

High-risk permission pattern: this.cache.delete(fileKey);

```
  251 |
  252 | ––çf Æ–F FR†f–ÆT¶W“¢ 7G&–ær“¢ fö–B °
> 253 | ™this.cache.delete(fileKey);
  254 | —Ð
  255 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#87 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/core/design-system-manifest.ts:1`

No logging, auditing, or monitoring detected

```
>   1 | /**
    2 |  * Design System Manifest Types
    3 |  *
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#88 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-api.ts:395`

High-risk permission pattern: * DELETE /v1/files/:file_key/comments/:comment_id

```
  393 |
  394 |   /**
> 395 |    * DELETE /v1/files/:file_key/comments/:comment_id
  396 |    * Delete a comment on a file…
  397 |    */
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#89 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-api.ts:396`

High-risk permission pattern: * Delete a comment on a file

```
  394 |   /**
  395 |    * DELETE /v1/files/:file_key/comments/:comment_id
> 396 |    * Delete a comment on a file
  397 |    */
  398 |   async deleteComment(fileKey: string, commentId: string): Promise<any> {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#90 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-api.ts:400`

High-risk permission pattern: method: 'DELETE',

```
  398 |   async deleteComment(fileKey: string, commentId: string): Promise<any> {
  399 |     return this.request(`/files/${fileKey}/comments/${commentId}`, {
> 400 |       method: 'DELETE',
  401 |     });
  402 |   }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#91 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/core/figma-connector.ts:1`

No logging, auditing, or monitoring detected

```
>   1 | /**
    2 |  * Figma Connector Interface
    3 |  *
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#92 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`src/core/figma-desktop-connector.ts:581`

Dangerous execution: // Check if this frame has the executeCode function (our Desktop Bridge plugin)

```
    579 |         }
    580 |
>   581 |         // Check if this frame has the executeCode function (our Desktop Bridge plugin)
    582 |         const hasWriteOps = await frame.evaluate('typeof window.executeCode === "function"');…
    583 |
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#93 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`src/core/figma-desktop-connector.ts:892`

Dangerous execution: var v = vars.variables.find(function(v) { return v.id === ${JSON.stringify(varia

```
    890 |           var vars = window.__figmaVariablesData;
    891 |           if (vars && vars.variables) {
>   892 |             var v = vars.variables.find(function(v) { return v.id ===
${JSON.stringify(variableId)}; });
    893 |             if (v) oldName = v.name;
    894 |           }
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#94 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`src/core/figma-desktop-connector.ts:997`

Dangerous execution: var mode = c.modes.find(function(m) { return m.modeId === ${JSON.stringify(model

```
    995 |               var c = colls[i];
    996 |               if (c.id === ${JSON.stringify(collectionId)}) {
>   997 |                 var mode = c.modes.find(function(m) { return m.modeId ===
${JSON.stringify(modeId)}; });
    998 |                 if (mode) oldName = mode.name;
    999 |                 break;
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#95 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:5`

High-risk permission pattern: * to execute code with access to the full Figma Plugin API,

```
      3 |  *
      4 |  * This service connects directly to Figma Desktop's plugin context
>     5 |  * to execute code with access to the full Figma Plugin API,
      6 |  * including variables without Enterprise access.
      7 |  *
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#96 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:63`

High-risk permission pattern: * Execute code in Figma's plugin context where the figma API is available

```
    61 |
    62 |   /**
>   63 |    * Execute code in Figma's plugin context where the figma API is available
    64 |    * Uses Puppeteer's direct worker access instead of CDP context enumeration…
    65 |    */
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#97 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:106`

High-risk permission pattern: // Execute the code in this worker context

```
   104 |             }, worker.url());
   105 |
>  106 |             // Execute the code in this worker context
   107 |             // Wrap the code in a function to ensure proper evaluation
   108 |             const wrappedCode = `(${code})`;
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#98 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:126`

High-risk permission pattern: logger.error({ error, code: code.substring(0, 200) }, 'Failed to execute in plug

```
   124 |       throw new Error('No plugin worker found with Figma API. Make sure a plugin is running in Figma
Desktop.');
   125 |     } catch (error) {
>  126 |       logger.error({ error, code: code.substring(0, 200) }, 'Failed to execute in plugin context');
   127 |       throw error;
   128 |     }
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#99 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:548`

High-risk permission pattern: // WRITE OPERATIONS - Execute commands via Plugin UI iframe

```
   546 |
   547 |   // ============================================================================
>  548 |   // WRITE OPERATIONS - Execute commands via Plugin UI iframe
   549 |   // ============================================================================…
   550 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#100 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:606`

High-risk permission pattern: * Execute arbitrary code in Figma's plugin context

```
   604 |
   605 |   /**
>  606 |    * Execute arbitrary code in Figma's plugin context
   607 |    * This is the power tool that can run any Figma Plugin API code
   608 |    * Includes retry logic for detached frame errors
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#101 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:779`

High-risk permission pattern: * Delete a variable

```
   777 |
   778 |   /**
>  779 |    * Delete a variable
   780 |    */
   781 |   async deleteVariable(variableId: string): Promise<any> {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#102 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:803`

High-risk permission pattern: logger.error({ error, variableId }, 'Delete variable failed');

```
   801 |       return result;
   802 |     } catch (error) {
>  803 |       logger.error({ error, variableId }, 'Delete variable failed');
   804 |       throw error;
   805 |     }
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#103 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:809`

High-risk permission pattern: * Delete a variable collection

```
   807 |
   808 |   /**
>  809 |    * Delete a variable collection
   810 |    */…
   811 |   async deleteVariableCollection(collectionId: string): Promise<any> {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#104 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:833`

High-risk permission pattern: logger.error({ error, collectionId }, 'Delete collection failed');

```
   831 |       return result;
   832 |     } catch (error) {
>  833 |       logger.error({ error, collectionId }, 'Delete collection failed');
   834 |       throw error;
   835 |     }
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#105 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:1198`

High-risk permission pattern: * Delete a component property

```
  1196 |
  1197 |   /**
> 1198 |    * Delete a component property
  1199 |    */
  1200 |   async deleteComponentProperty(nodeId: string, propertyName: string): Promise<any> {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#106 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:1213`

High-risk permission pattern: logger.error({ error, nodeId, propertyName }, 'Delete component property failed'

```
  1211 |       return result;
  1212 |     } catch (error) {
> 1213 |       logger.error({ error, nodeId, propertyName }, 'Delete component property failed');
  1214 |       throw error;…
  1215 |     }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#107 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:1370`

High-risk permission pattern: * Delete a node

```
  1368 |
  1369 |   /**
> 1370 |    * Delete a node
  1371 |    */
  1372 |   async deleteNode(nodeId: string): Promise<any> {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#108 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-desktop-connector.ts:1385`

High-risk permission pattern: logger.error({ error, nodeId }, 'Delete node failed');

```
  1383 |       return result;
  1384 |     } catch (error) {
> 1385 |       logger.error({ error, nodeId }, 'Delete node failed');
  1386 |       throw error;
  1387 |     }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#109 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-tools.ts:424`

High-risk permission pattern: delete variable.valuesByMode;

```
    422 | ™−−b ‡fW&&÷6—G’ ÓÓÒ &–çfVçF÷''"’ °
    423 | ™™// Inventory: Remove valuesByMode entirely, add mode count
>   424 | ™™delete variable.valuesByMode;
    425 | ™™if (collection?.modes) {
    426 | ™™—f &– &ÆRæÖöFT6÷VçB Ò 6öÆÆV7F–öâæÖöFW2æÆVæwFƒ°
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#110 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-tools.ts:434`

High-risk permission pattern: delete variable.valuesByMode;

```
  432 | ™™—f &– &ÆRæÖöFT6÷VçB Ò 6öÆÆV7F–öâæÖöFW2æÆVæwFƒ°
  433 | ™™}
> 434 | ™™delete variable.valuesByMode;
  435 | ™—Ò VÇ6R –b ‡fW&&÷6—G’ ÓÓÒ '7F æF &B"’ ¸P
  436 | ™™// Standard: If mode parameter specified, filter to that mode only
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#111 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/figma-tools.ts:564`

High-risk permission pattern: cache.delete(oldestKey);

```
  562 |
  563 | ™if (oldestKey) {
> 564 | ™–6 6†RæFVÆWFR†öÆFW7D¶W’“°
  565 | ™–ÆövvW"æ–æfò‡² Wf–7FVD¶W“¢ öÆFW7D¶W’ ÒÂ tWf–7FVB öÆFW7B 6 6†R VçG'' „Å%R’r“°
  566 | ™}
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#112 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`src/core/logger.ts:5`

Dependency without integrity verification

```
    3 |  */
    4 |
>   5 | import pino from 'pino';
    6 |
    7 | /**
```

Remediation:
1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#113 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`src/core/port-discovery.ts:320`

Dangerous execution: const { execSync } = require('child_process');

```
   318 |     try {
   319 |       // Find PIDs listening on this port via lsof
>  320 |       const { execSync } = require('child_process');
   321 |       const output = execSync(`lsof -i :${port} -sTCP:LISTEN -t 2>/dev/null`, {…
   322 |         encoding: 'utf-8',
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#114 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`src/core/port-discovery.ts:360`

Dangerous execution: const { execSync } = require('child_process');

```
   358 |     // Give terminated processes a moment to release their ports
   359 |     try {
>  360 |       const { execSync } = require('child_process');
   361 |       execSync('sleep 0.5', { timeout: 2000 });
   362 |     } catch { /* non-critical */ }
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#115 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/port-discovery.ts:246`

High-risk permission pattern: * 1. Dead PID — process no longer exists !' delete file

```
   244 |  *
   245 |  * Runs at startup before port binding. Detects stale instances via:
>  246 |  *   1. Dead PID — process no longer exists !' delete file
   247 |  *   2. Zombie process — alive but stale (no heartbeat or expired heartbeat)
   248 |  *      !' send SIGTERM to free the port, then delete file
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#116 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/port-discovery.ts:248`

High-risk permission pattern: * !' send SIGTERM to free the port, then delete file

```
   246 |  *   1. Dead PID — process no longer exists !' delete file
   247 |  *   2. Zombie process — alive but stale (no heartbeat or expired heartbeat)
>  248 |  *      !' send SIGTERM to free the port, then delete file
   249 |  *   3. Corrupt file — invalid JSON !' delete file
   250 |  */
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#117 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/port-discovery.ts:249`

High-risk permission pattern: * 3. Corrupt file — invalid JSON !' delete file

```
  247 |  *   2. Zombie process — alive but stale (no heartbeat or expired heartbeat)
  248 |  *      !' send SIGTERM to free the port, then delete file
> 249 |  *   3. Corrupt file — invalid JSON !' delete file
  250 |  */…
  251 | export function cleanupStalePortFiles(): number {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#118 AS-006 -- SANDBOXING

HIGH

OWASP: AA-09 | MITRE: T1610 | STRIDE: Elevation of Privilege

Code execution without sandboxing or isolation mechanisms

`src/core/port-discovery.ts:320`

Code execution without sandboxing

```
  318 |     try {
  319 |       // Find PIDs listening on this port via lsof
> 320 |       const { execSync } = require('child_process');
  321 |       const output = execSync(`lsof -i :${port} -sTCP:LISTEN -t 2>/dev/null`, {
  322 |         encoding: 'utf-8',
```

Remediation:
1. Run all agent-generated code in Docker containers with --network=none and read-only filesystem. 2. Use gVisor/Firecracker for stronger isolation. 3. Set resource limits (CPU, memory, time) on execution. 4. Use E2B or Modal for managed sandboxed execution. 5. Never execute agent code in the host process.

MCPS Quick Fix: npm install mcp-secure

#119 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`src/core/port-discovery.ts:320`

Dependency without integrity verification

```
  318 |     try {
  319 |       // Find PIDs listening on this port via lsof
> 320 |       const { execSync } = require('child_process');
  321 |       const output = execSync(`lsof -i :${port} -sTCP:LISTEN -t 2>/dev/null`, {
  322 |         encoding: 'utf-8',
```

Remediation:
1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#120 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`src/core/port-discovery.ts:360`

Dependency without integrity verification

```
   358 |     // Give terminated processes a moment to release their ports
   359 |     try {
>  360 |       const { execSync } = require('child_process');
   361 |       execSync('sleep 0.5', { timeout: 2000 });…
   362 |     } catch { /* non-critical */ }
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#121 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/core/types/design-code.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * TypeScript types for Design-Code Parity Checker & Documentation Generator
     3 |  */
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#122 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`src/core/websocket-connector.ts:64`

Dangerous execution: variables: variables.map(function(v) { return { id: v.id, name: v.name, key: v.k

```
    62 |             timestamp: Date.now(),
    63 |             fileMetadata: { fileName: figma.root.name, fileKey: figma.fileKey || null },
>   64 |             variables: variables.map(function(v) { return { id: v.id, name: v.name, key: v.key,
resolvedType: v.resolvedType, valuesByMode: v.valuesByMode, variableCollectionId: v.variableCollectionId,
scopes: v.scopes, description: v.description, hiddenFromPublishing: v.hiddenFromPublishing }; }),
    65 |             variableCollections: collections.map(function(c) { return { id: c.id, name: c.name, key:
c.key, modes: c.modes, defaultModeId: c.defaultModeId, variableIds: c.variableIds }; })
    66 |           };
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#123 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`src/core/websocket-connector.ts:65`

Dangerous execution: variableCollections: collections.map(function(c) { return { id: c.id, name: c.na

```
    63 |             fileMetadata: { fileName: figma.root.name, fileKey: figma.fileKey || null },
    64 |             variables: variables.map(function(v) { return { id: v.id, name: v.name, key: v.key,
resolvedType: v.resolvedType, valuesByMode: v.valuesByMode, variableCollectionId: v.variableCollectionId,
scopes: v.scopes, description: v.description, hiddenFromPublishing: v.hiddenFromPublishing }; }),
>   65 |             variableCollections: collections.map(function(c) { return { id: c.id, name: c.name, key:
c.key, modes: c.modes, defaultModeId: c.defaultModeId, variableIds: c.variableIds }; })
    66 |           };
    67 |         } catch (error) {
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#124 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/websocket-connector.ts:51`

High-risk permission pattern: // Execute the same variables-fetching code in the plugin worker context

```
    49 |
    50 |   async getVariables(fileKey?: string): Promise<any> {
>   51 |     // Execute the same variables-fetching code in the plugin worker context
    52 |     const code = `…
    53 |       (async () => {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#125 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/websocket-server.ts:266`

High-risk permission pattern: this._pendingClients.delete(ws);

```
   264 |           const pendingTimeout = setTimeout(() => {
   265 |             if (this._pendingClients.has(ws)) {
>  266 |               this._pendingClients.delete(ws);
   267 |               logger.warn('Pending WebSocket client timed out without sending FILE_INFO');
   268 |               ws.close(1000, 'File identification timeout');
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#126 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/websocket-server.ts:344`

High-risk permission pattern: this.pendingRequests.delete(message.id);

```
   342 |       const pending = this.pendingRequests.get(message.id)!;
   343 |       clearTimeout(pending.timeoutId);
>  344 |       this.pendingRequests.delete(message.id);
   345 |
   346 |       if (message.error) {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#127 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/websocket-server.ts:465`

High-risk permission pattern: this._pendingClients.delete(ws);

```
  463 |     if (pendingTimeout) {
  464 |       clearTimeout(pendingTimeout);
> 465 |       this._pendingClients.delete(ws);
  466 |     }…
  467 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#128 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/websocket-server.ts:472`

High-risk permission pattern: this.clients.delete(previousEntry.fileKey);

```
  470 |     const previousEntry = this.findClientByWs(ws);
  471 |     if (previousEntry && previousEntry.fileKey !== fileKey) {
> 472 |       this.clients.delete(previousEntry.fileKey);
  473 |       if (this._activeFileKey === previousEntry.fileKey) {
  474 |         this._activeFileKey = null;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#129 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/websocket-server.ts:544`

High-risk permission pattern: this._pendingClients.delete(ws);

```
  542 |     if (pendingTimeout) {
  543 |       clearTimeout(pendingTimeout);
> 544 |       this._pendingClients.delete(ws);
  545 |       logger.info('Pending WebSocket client disconnected before file identification');
  546 |       this.emit('disconnected');
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#130 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/websocket-server.ts:570`

High-risk permission pattern: this.clients.delete(fileKey);

```
  568 |       const current = this.clients.get(fileKey);
  569 |       if (current && current.ws === ws) {
> 570 |         this.clients.delete(fileKey);
  571 |         this.rejectPendingRequestsForFile(fileKey, 'WebSocket client disconnected');
  572 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#131 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/websocket-server.ts:614`

High-risk permission pattern: this.pendingRequests.delete(id);

```
   612 |       const timeoutId = setTimeout(() => {
   613 |         if (this.pendingRequests.has(id)) {
>  614 |           this.pendingRequests.delete(id);
   615 |           reject(new Error(`WebSocket command ${method} timed out after ${timeoutMs}ms`));…
   616 |         }
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#132 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/websocket-server.ts:632`

High-risk permission pattern: this.pendingRequests.delete(id);

```
   630 |         client.ws.send(message);
   631 |       } catch (sendError) {
>  632 |         this.pendingRequests.delete(id);
   633 |         clearTimeout(timeoutId);
   634 |         reject(new Error(`Failed to send WebSocket command ${method}: ${sendError instanceof Error ?
sendError.message : String(sendError)}`));
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#133 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/websocket-server.ts:853`

High-risk permission pattern: this.pendingRequests.delete(id);

```
   851 |         clearTimeout(pending.timeoutId);
   852 |         pending.reject(new Error(reason));
>  853 |         this.pendingRequests.delete(id);
   854 |       }
   855 |     }
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#134 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:21`

High-risk permission pattern: `Execute arbitrary JavaScript in Figma's plugin context with full access to the

```
    19 | –6W'fW"çFööÂ€
    20 | ™"figma_execute",
>   21 | ™`Execute arbitrary JavaScript in Figma's plugin context with full access to the figma API. Use for
complex operations not covered by other tools. Requires Desktop Bridge plugin. CAUTION: Can modify your
document.
    22 |
    23 | **COMPONENT INSTANCES:** For instances (node.type === 'INSTANCE'), use figma_set_instance_properties
— direct text editing FAILS SILENTLY. Check instance.componentProperties for available props (may have…
#nodeId suffixes).
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#135 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:35`

High-risk permission pattern: On failure/retry: DELETE any partial artifacts (empty frames, orphaned layers, b

```
    33 | When creating: place inside a named Section, positioned BELOW or AWAY from existing content. Never
overlap.
    34 | After creating: screenshot to verify clean placement and no overlaps.
>   35 | On failure/retry: DELETE any partial artifacts (empty frames, orphaned layers, blank pages) before
retrying. Use node.remove() to clean up.
    36 | Pages: NEVER create a new page if one with that name already exists — use the existing one. If you
created a blank page during a failed attempt, delete it.
    37 | Layers: If your code creates helper frames, placeholder nodes, or intermediate layers that aren't
part of the final result, remove them.`,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#136 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:36`

High-risk permission pattern: Pages: NEVER create a new page if one with that name already exists — use the ex

```
    34 | After creating: screenshot to verify clean placement and no overlaps.
    35 | On failure/retry: DELETE any partial artifacts (empty frames, orphaned layers, blank pages) before
retrying. Use node.remove() to clean up.
>   36 | Pages: NEVER create a new page if one with that name already exists — use the existing one. If you
created a blank page during a failed attempt, delete it.
    37 | Layers: If your code creates helper frames, placeholder nodes, or intermediate layers that aren't
part of the final result, remove them.`,
    38 | ™{
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#137 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:42`

High-risk permission pattern: "JavaScript code to execute. Has access to the 'figma' global object. " +

```
    40 | ™™.string()
    41 | ™™.describe(
>   42 | ™™’$¦ f 67&— B 6öFR Fò W†V7WFRâ † 2  66W72 Fò F†R vf–vÖ r vÆö& Â ö&¦V7Bâ " °
    43 | ™™™"Example: 'const rect = figma.createRectangle(); rect.resize(100, 100); return { id: rect.id };'",…
    44 | ™™),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#138 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:81`

High-risk permission pattern: "Failed to execute code in Figma plugin context",

```
    79 | ™™logger.error(
    80 | ™™—² W'&÷" ÒÀ
>   81 | ™™’$f –ÆVB Fò W†V7WFR 6öFR –â f–vÖ   ÇVv–â 6öçFW‡B"À
    82 | ™™);
    83 | ™™return {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#139 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:91`

High-risk permission pattern: message: "Failed to execute code in Figma plugin context",

```
    89 | ™™™™™–W'&÷#
    90 | ™™™™™™error instanceof Error ? error.message : String(error),
>   91 | ™™™™™–ÖW76 vS¢ $f –ÆVB Fò W†V7WFR 6öFR –â f–vÖ   ÇVv–â 6öçFW‡B"À
    92 | ™™™™™–†–çC¢ $Ö ¶R 7W&R F†R FW6·F÷  '&–FvR  ÇVv–â —2 'Vææ–ær –â f–vÖ "À
    93 | ™™™™™},
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#140 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:323`

High-risk permission pattern: // Tool: Delete a variable

```
   321 | ’“°
   322 |
>  323 | ’òò FööÃ¢ FVÆWFR   f &– &ÆP
   324 | —6W'fW"çFööÂ€
   325 | ™"figma_delete_variable",
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#141 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:326`

High-risk permission pattern: "Delete a Figma variable. WARNING: This is a destructive operation that cannot b

```
   324 | –6W'fW"çFööÂ€
   325 | ™"figma_delete_variable",
>  326 | ™"Delete a Figma variable. WARNING: This is a destructive operation that cannot be undone (except
with Figma's undo). Use figma_get_variables first to get variable IDs. Requires the Desktop Bridge plugin to
be running.",
   327 | ™{…
   328 | ™–f &– &ÆT–C¢
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#142 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:331`

High-risk permission pattern: "The variable ID to delete (e.g., 'VariableID:123:456'). Get this from figma_get

```
   329 | ™™.string()
   330 | ™™.describe(
>  331 | ™™'%F†R f &– &ÆR "B Fò FVÆWFR †RærâÂ uf &– &ÆT"C£ #3£CSbr'â vWB F†–2 g&öÒ f–vÖ övWE÷f &– &ÆW2â"À
   332 | ™™),
   333 | ™},
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#143 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:357`

High-risk permission pattern: logger.error({ error }, "Failed to delete variable");

```
   355 | ™™};
   356 | ™–Ò 6 F6, †W'&÷"' °
>  357 | ™™logger.error({ error }, "Failed to delete variable");
   358 | ™™return {
   359 | ™™–6öçFVçC¢ °
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#144 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

src/core/write-tools.ts:366

High-risk permission pattern: message: "Failed to delete variable",

```
   364 | ™™™™–W'&÷#
   365 | ™™™™™™error instanceof Error ? error.message : String(error),
>  366 | ™™™™–ÖW76 vS¢ $f –ÆVB Fò FVÆWFR f &– &ÆR"À
   367 | ™™™™–†–çC¢ $Ö ¶R 7W&R F†R FW6·F÷  '&–FvR  ÇVv–â –2 'Vææ–ær  æB F†R f &– &ÆR ”B –2 6÷'&V7B"ÈP
   368 | ™™™™},
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#145 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

src/core/write-tools.ts:378

High-risk permission pattern: // Tool: Delete a variable collection

```
   376 | ’“°
   377 |
>  378 | ’òò FööÃ¢ FVÆWFR   f &– &ÆR 6öÆÆV7F–öà
   379 | –6W'fW"çFööÂ€
   380 | ™"figma_delete_variable_collection",
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#146 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

src/core/write-tools.ts:381

High-risk permission pattern: "Delete a Figma variable collection and ALL its variables. WARNING: This is a de

```
   379 | –6W'fW"çFööÂ€
   380 | ™"figma_delete_variable_collection",
>  381 | ™"Delete a Figma variable collection and ALL its variables. WARNING: This is a destructive operation
that deletes all variables in the collection and cannot be undone (except with Figma's undo). Requires the
Desktop Bridge plugin to be running.",
   382 | ™{
   383 | ™–6öÆÆV7F–öä–C¢
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#147 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

src/core/write-tools.ts:386

High-risk permission pattern: "The collection ID to delete (e.g., 'VariableCollectionId:123:456'). Get this fr

```
   384 | ™™.string()
   385 | ™™.describe(
>  386 | ™™’%F†R 6öÆÆV7F–öâ ”B Fò FVÆWFR †RærâÂ uf &– &ÆT6öÆÆV7F–öä–C£ #3£CSbr’â vWB F†–2 g&öÒ
figma_get_variables.",
   387 | ™™),
   388 | ™},
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#148 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:412`

High-risk permission pattern: logger.error({ error }, "Failed to delete collection");

```
  410 | ™™};
  411 | ™—Ò 6 F6, †W'&÷"' °
> 412 | ™™logger.error({ error }, "Failed to delete collection");
  413 | ™™return {…
  414 | ™™–6öçFVçC¢ °
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#149 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:421`

High-risk permission pattern: message: "Failed to delete variable collection",

```
  419 | ™™™™™–W'&÷#
  420 | ™™™™™™error instanceof Error ? error.message : String(error),
> 421 | ™™™™™–ÖW76 vS¢ $f –ÆVB Fò FVÆWFR f &– &ÆR 6öÆÆV7F–öâ"À
  422 | ™™™™™–†–çC¢ $Ô ¶R 7W&R F†R FW6·F÷  '&–FvR  ÇVv–â —2 'Vææ–ær  æB F†R 6öÆÆV7F–öâ ”B —2 6÷'&V7B"À
  423 | ™™™™™},
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#150 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:622`

High-risk permission pattern: // Execute multiple variable operations in a single roundtrip,

```
  620 | ’òò $ D4, õ U$ D”ôå2 … W&f÷&Ö æ6RÔ÷ F–Ö—¦VB•
  621 | ’òò ÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÓÐ
> 622 | ’òò W†V7WFR ×VÇF— ÆR f &– &ÆR ÷ W& F–öç2 –â   6–ævÆR &÷VæGG&— À
  623 | ’òò &VGV6–ær  W"Ö÷ W& F–öâ ÷fW&†V B g&öÔ ãc Ó s ×2 Fò æV "×¦W&òà
  624 | ’òò W6R F†W6R –ç7FV B öb 6 ÆÆ–ær –æF—f–GV Â FööÇ2 &W V FVFÇ’à
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#151 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:1408`

High-risk permission pattern: // Tool: Delete Component Property

```
  1406 | ’“°
  1407 |
> 1408 | ’òò FööÃ¢ FVÆWFR 6ö× öæVçB  &÷ W'G•
  1409 | –6W'fW"çFööÂˆP
  1410 | ™"figma_delete_component_property",
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#152 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:1411`

High-risk permission pattern: "Delete a component property. Only works with BOOLEAN, TEXT, and INSTANCE_SWAP p

```
  1409 | –6W'fW"çFööÂ€
  1410 | ™"figma_delete_component_property",
> 1411 | ™"Delete a component property. Only works with BOOLEAN, TEXT, and INSTANCE_SWAP properties (not
VARIANT). This is a destructive operation.",
  1412 | ™{
  1413 | ™–æöFT–C¢ ¢ç7G&–ær,’æFW67&–&R,%F†R 6ö× öæVçB ÷" 6ö× öæVçB 6WB æöFR ”B"’À
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#153 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:1429`

High-risk permission pattern: throw new Error(result.error || "Failed to delete property");

```
  1427 |
  1428 | ™™if (!result.success) {
> 1429 | ™™—F‡&÷r æWr W'&÷"‡&W7VÇBæW'&÷" ÇÂ $f –ÆVB Fò FVÆWFR  &÷ W'G’"“°
  1430 | ™™}
  1431 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#154 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:1446`

High-risk permission pattern: logger.error({ error }, "Failed to delete component property");

```
  1444 | ™™};
  1445 | ™—Ò 6 F6, †W'&÷"’ °
> 1446 | ™™logger.error({ error }, "Failed to delete component property");
  1447 | ™™return {
  1448 | ™™–6öçFVçC¢ °
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#155 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:1455`

High-risk permission pattern: hint: "Cannot delete VARIANT properties. Only BOOLEAN, TEXT, and INSTANCE_SWAP c

```
  1453 | ™™™™™–W'&÷#
  1454 | ™™™™™™error instanceof Error ? error.message : String(error),
> 1455 | ™™™™™–†–çC¢ $6 ææ÷B FVÆWFR d $” åB  &÷ W'F–W2â öæÇ’ $ôôÄT âÂ DU…BÂ  æB ”å5D ä4Uõ5t   6 â &R FVÆWFVBâ"À
  1456 | ™™™™™},…
  1457 | ™™™™’’À
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#156 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:1821`

High-risk permission pattern: // Tool: Delete Node

```
  1819 | ’“°
  1820 |
> 1821 | ’òò FööÃ¢ FVÆWFR æöFP
  1822 | –6W'fW"çFööÂ€
  1823 | ™"figma_delete_node",
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#157 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:1824`

High-risk permission pattern: "Delete a node from the canvas. WARNING: This is a destructive operation (can be

```
  1822 | –6W'fW"çFööÂ€
  1823 | ™"figma_delete_node",
> 1824 | ™"Delete a node from the canvas. WARNING: This is a destructive operation (can be undone with Figma's
undo).",
  1825 | ™{
  1826 | ™–æöFT–C¢ ¢ç7G&–ær,’æFW67&–&R,%F†R æöFR ”B Fò FVÆWFR"’À
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#158 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:1826`

High-risk permission pattern: nodeId: z.string().describe("The node ID to delete"),

```
  1824 | ™"Delete a node from the canvas. WARNING: This is a destructive operation (can be undone with Figma's
undo).",
  1825 | ™{
> 1826 | ™–æöFT–C¢ ¢ç7G&–ær,'æFW67&–&R,%F†R æöFR ”B Fò FVÆWFR"'À
  1827 | ™},…
  1828 | ™async ({ nodeId }) => {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#159 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:1834`

High-risk permission pattern: throw new Error(result.error || "Failed to delete node");

```
  1832 |
  1833 | ™™if (!result.success) {
> 1834 | ™™—F‡&÷r æWr W'&÷"‡&W7VÇBæW'&÷" ÇÂ $f –ÆVB Fò FVÆWFR æöFR"“°
  1835 | ™™}
  1836 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#160 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:1852`

High-risk permission pattern: logger.error({ error }, "Failed to delete node");

```
  1850 | ™™};
  1851 | ™—Ò 6 F6, †W'&÷"’ °
> 1852 | ™™logger.error({ error }, "Failed to delete node");
  1853 | ™™return {
  1854 | ™™–6öçFVçC¢ °
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#161 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:2112`

High-risk permission pattern: // Build the code to execute in Figma

```
  2110 | ™™const connector = await getDesktopConnector();
  2111 |
> 2112 | ™™// Build the code to execute in Figma
  2113 | ™™const code = `
  2114 | // ==========================================================================
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#162 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/core/write-tools.ts:2260`

High-risk permission pattern: // Delete the old component set

```
  2258 | }
  2259 |
> 2260 | // Delete the old component set
  2261 | componentSet.remove();…
  2262 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#163 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`src/index.ts:3189`

Dangerous execution: (function() {

```
  3187 | “Ç67&— Cà
  3188 | ™// Theme toggle with system preference detection
> 3189 | ™(function() {
  3190 | ™–6öç7B ‡FÒÂ Ò Fö7VÖVçBæFö7VÖVçDVÆVÖVçC°
  3191 | ™–6öç7B FövvÆR Ò Fö7VÖVçBç VW'•6VÆV7F÷",rçF†VÖR×FövvÆRr“°
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#164 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`src/index.ts:3238`

Dangerous execution: (function() {

```
  3236 |
  3237 | ™// Mobile menu toggle
> 3238 | ™(function() {
  3239 | ™–6öç7B ÖVçT'Fâ Ò Fö7VÖVçBç VW'•6VÆV7F÷",ræÖö&–ÆRÖÖVçRÖ'Fâr“°
  3240 | ™–6öç7B ÖVçR Ò Fö7VÖVçBævWDVÆVÖVçD'”–B,vÖö&–ÆTÖVçRr“°
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#165 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/index.ts:1045`

High-risk permission pattern: // Delete used code (one-time use)

```
  1043 | ™—Ð
  1044 |
> 1045 | ™’òò FVÆWFR W6VB 6öFR †öæR×F–ÖR W6R•
  1046 | ™– v —B VçbäÔ UD…õDÔ´Tå2æFVÆWFR‡  —&–æt¶W’“¸P
  1047 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#166 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/index.ts:1046`

High-risk permission pattern: await env.OAUTH_TOKENS.delete(pairingKey);

```
  1044 |
  1045 | ™’òò FVÆWFR W6VB 6öFR †öæR×F–ÖR W6R•
> 1046 | ™– v —B VçbäÔ UD…õDÔ´Tå2æFVÆWFR‡  —&–æt¶W’“°
  1047 |
  1048 | ™’òò f÷'v &B vV%6ö6¶WB W w& FR Fò F†R &VÆ ’ Dð
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#167 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/index.ts:1748`

High-risk permission pattern: // Delete state token after validation (one-time use)

```
  1746 | ™—Ð
  1747 |
> 1748 | ™’òò FVÆWFR 7F FR Fö¶Vâ  gFW" f Æ–F F–öâ †öæR×F–ÖR W6R•
  1749 | ™– v —B VçbäÔ UD…õ5D DRæFVÆWFR‡7F FUFö¶Vâ“°
  1750 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#168 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/index.ts:1749`

High-risk permission pattern: await env.OAUTH_STATE.delete(stateToken);

```
  1747 |
  1748 | ™’òò FVÆWFR 7F FR Fö¶Vâ  gFW" f Æ–F F–öâ †öæR×F–ÖR W6R•
> 1749 | ™– v —B VçbäÔ UD…õ5D DRæFVÆWFR‡7F FUFö¶Vâ“°
  1750 |
  1751 | ™—G'' °
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#169 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/index.ts:1858`

High-risk permission pattern: await env.OAUTH_STATE.delete(mcpStateKey);

```
  1856 |
  1857 | ™™’òò 6ÆV â W  F†R Ô5   WF, 7F FP
> 1858 | ™™– v –B VçbäÔ UD…õ5D DRæFVÆWFR†Ö7 7F FT¶W’“°
  1859 |…
  1860 | ™™’òò vVæW& FR  â  WF†÷&–¦ F–öâ 6öFR f÷" F†R Ô5  6Æ–Vç@
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#170 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

`src/index.ts:1962`

Known injection pattern detected

```
  1960 | ™<div class="footer">This window will automatically close in 5 seconds</div>
  1961 | “ÂöF–cà
> 1962 | “Ç67&– Cà
  1963 | ™setTimeout(() => window.close(), 5000);
  1964 | “Â÷67&– Cà
```

Remediation:
1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#171 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

`src/index.ts:3187`

Known injection pattern detected

```
  3185 | “Âöfö÷FW#à
  3186 |
> 3187 | “Ç67&– Cà
  3188 | ™// Theme toggle with system preference detection
  3189 | ™(function() {
```

Remediation:
1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#172 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:139`

High-risk permission pattern: 1. **CREATE: Execute design code via figma_execute**

```
   137 | ### VISUAL VALIDATION WORKFLOW (Required)
   138 | After creating or modifying ANY visual design elements:
>  139 | 1. **CREATE**: Execute design code via figma_execute
   140 | 2. **SCREENSHOT**: Capture result with figma_take_screenshot…
   141 | 3. **ANALYZE**: Check alignment, spacing, proportions, visual balance
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#173 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:189`

High-risk permission pattern: Batch tools are 10-50x faster because they execute in a single roundtrip. Use in

```
   187 | - **figma_setup_design_tokens**: Create a complete token system (collection + modes + variables)
atomically in one call
   188 |
>  189 | Batch tools are 10-50x faster because they execute in a single roundtrip. Use individual tools only
for one-off operations.
   190 |
   191 | ### DESIGN BEST PRACTICES
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#174 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:1801`

High-risk permission pattern: // Tool: Execute arbitrary code in Figma plugin context (Power Tool)

```
  1799 | ™// ==========================================================================
  1800 |
> 1801 | ™// Tool: Execute arbitrary code in Figma plugin context (Power Tool)
  1802 | ™this.server.tool(
  1803 | ™’&f–vÖ öW†V7WFR"À
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#175 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:1804`

High-risk permission pattern: `Execute arbitrary JavaScript in Figma's plugin context with full access to the

```
  1802 | ™this.server.tool(
  1803 | ™’&f–vÖ öW†V7WFR"À
> 1804 | ™– W†V7WFR  &&—G& '’ ¦ f 67&— B –â f–vÖ w2  ÇVv–â 6öçFW‡B v—F, gVÆÂ  66W72 Fò F†R f–vÖ    ’â W6R f÷"
complex operations not covered by other tools. Requires Desktop Bridge plugin. CAUTION: Can modify your
document.
  1805 |
  1806 | **COMPONENT INSTANCES:** For instances (node.type === 'INSTANCE'), use figma_set_instance_properties
— direct text editing FAILS SILENTLY. Check instance.componentProperties for available props (may have
#nodeId suffixes).
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#176 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:1818`

High-risk permission pattern: On failure/retry: DELETE any partial artifacts (empty frames, orphaned layers, b

```
  1816 | When creating: place inside a named Section, positioned BELOW or AWAY from existing content. Never
overlap.
  1817 | After creating: screenshot to verify clean placement and no overlaps.
> 1818 | On failure/retry: DELETE any partial artifacts (empty frames, orphaned layers, blank pages) before
retrying. Use node.remove() to clean up.
  1819 | Pages: NEVER create a new page if one with that name already exists — use the existing one. If you
created a blank page during a failed attempt, delete it.
  1820 | Layers: If your code creates helper frames, placeholder nodes, or intermediate layers that aren't…
part of the final result, remove them.`,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#177 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:1819`

High-risk permission pattern: Pages: NEVER create a new page if one with that name already exists — use the ex

```
  1817 | After creating: screenshot to verify clean placement and no overlaps.
  1818 | On failure/retry: DELETE any partial artifacts (empty frames, orphaned layers, blank pages) before
retrying. Use node.remove() to clean up.
> 1819 | Pages: NEVER create a new page if one with that name already exists — use the existing one. If you
created a blank page during a failed attempt, delete it.
  1820 | Layers: If your code creates helper frames, placeholder nodes, or intermediate layers that aren't
part of the final result, remove them.`,
  1821 | ™—°
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#178 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:1825`

High-risk permission pattern: "JavaScript code to execute. Has access to the 'figma' global object. " +

```
  1823 | ™™′ç7G&–ær,•
  1824 | ™™′æFW67&–&R€
> 1825 | ™™™"JavaScript code to execute. Has access to the 'figma' global object. " +
  1826 | ™™™′$W† × ÆS¢ v6öç7B &V7B Ò f–vÖ æ7&V FU&V7F ævÆR,“² &V7Bç&W6–¦Rƒ   Â    “² &WGW&â ² –C¢ &V7Bæ–B Ó²r"À
  1827 | ™™′′À
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#179 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:1866`

High-risk permission pattern: if (pageNames[name] > 1) warnings.push('DUPLICATE_PAGE: ' + pageNames[name] + '

```
  1864 | ™™™™™—Ð
  1865 | ™™™™™–f÷" ‡f " æ ÖR –â   vTæ ÖW2’ °
> 1866 | ™™™™™™if (pageNames[name] > 1) warnings.push('DUPLICATE_PAGE: ' + pageNames[name] + ' pages named "' +
name + '" — delete the empty duplicate');
  1867 | ™™™™™™—ØP
  1868 | ™™™™™™’òò 6†V6² f÷" V× G’   vW2 †Æ–¶VÇ’ g&öÒ f –ÆVB  GFV× G2•
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#180 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:1871`

High-risk permission pattern: warnings.push('EMPTY_PAGE: "' + pages[i].name + '" has no content — delete if un

```
  1869 | ™™™™™™–f÷" ‡f " ’ Ò  ² ’ Â   vW2æÆVæwFƒ² ’²²’ °
  1870 | ™™™™™™™if (pages[i].children.length === 0 && pages[i].name !== '---') {
> 1871 | ™™™™™™™—v &æ–æw2ç W6,,tTÕ E•õ  tS¢ "r ²   vW5¶•Ôææ ÖR ² r" † 2 æò 6öçFVçB r FVÆWFR –b Væ–çFVæFVBr“°
  1872 | ™™™™™™™}
  1873 | ™™™™™™—Ð
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#181 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:1910`

High-risk permission pattern: ai_instruction: "CLEANUP REQUIRED: The warnings above indicate housekeeping issu

```
  1908 | ™™™™™—&W7 öç6Ræ†÷W6V¶VW –ær Ò °
  1909 | ™™™™™™warnings: housekeepingWarnings,
> 1910 | ™™™™™™ai_instruction: "CLEANUP REQUIRED: The warnings above indicate housekeeping issues from your recent
operation. Fix these NOW before proceeding — delete empty/duplicate pages, remove orphaned nodes, and move
floating content into Sections.",
  1911 | ™™™™™—Ó°
  1912 | ™™™™™}
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#182 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:1971`

High-risk permission pattern: "Failed to execute code after retries",

```
  1969 | ™™™logger.error(
  1970 | ™™™—² W'&÷#¢ Æ 7DW'&÷" ÒÀ
> 1971 | ™™™’$f –ÆVB Fò W†V7WFR 6öFR  gFW" &WG&–W2"À
  1972 | ™™™);
  1973 | ™™™return {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#183 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:1980`

High-risk permission pattern: message: "Failed to execute code in Figma plugin context",

```
  1978 | ™™™™{
  1979 | ™™™™–W'&÷#¢ Æ 7DW'&÷#òæÖW76 vR ÇÂ %Væ¶æ÷vâ W'&÷""À
> 1980 | ™™™™–ÖW76 vS¢ $f –ÆVB Fò W†V7WFR 6öFR –â f–vÖ   ÇVv–â 6öçFW‡B"À
  1981 | ™™™™–†–çC¢ $Ö ¶R 7W&R F†R FW6·F÷  '&–FvR  ÇVv–â —2 'Vææ–ær –â f–vÖ "ÈP
  1982 | ™™™™},
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#184 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:2207`

High-risk permission pattern: // Tool: Delete a variable

```
  2205 | ™);
  2206 |
> 2207 | ™// Tool: Delete a variable
  2208 | ™this.server.tool(
  2209 | ™'&f–vÖ öFVÆWFU÷f &– &ÆR"À
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#185 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:2210`

High-risk permission pattern: "Delete a Figma variable. WARNING: This is a destructive operation that cannot b

```
  2208 | ™this.server.tool(
  2209 | ™'&f–vÖ öFVÆWFU÷f &– &ÆR"À
> 2210 | ™'$FVÆWFR   f–vÖ  f &– &ÆRâ t $ä"äs¢ F†—2 —2   FW7G'V7F—fR ÷ W& F–öâ F† B 6 ææ÷B &R VæFöæR †W†6W B
with Figma's undo). Use figma_get_variables first to get variable IDs. Requires the Desktop Bridge plugin to
be running.",
  2211 | ™—°
  2212 | ™™variableId: z
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#186 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:2215`

High-risk permission pattern: "The variable ID to delete (e.g., 'VariableID:123:456'). Get this from figma_get

```
  2213 | ™™™’ç7G&–ær,•
  2214 | ™™™’æFW67&–&R€
> 2215 | ™™™™"The variable ID to delete (e.g., 'VariableID:123:456'). Get this from figma_get_variables.",
  2216 | ™™™’’ÈP
  2217 | ™–ÒÀ
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#187 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:2241`

High-risk permission pattern: logger.error({ error }, "Failed to delete variable");

```
  2239 | ™™™–Ó°
  2240 | ™™™} catch (error) {
> 2241 | ™™™–ÆövvW"æW'&÷"‡² W'&÷" ÒÂ $f –ÆVB Fò FVÆWFR f &– &ÆR"“°
  2242 | ™™™–&WGW&â °
  2243 | ™™™™content: [
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#188 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:2250`

High-risk permission pattern: message: "Failed to delete variable",

```
  2248 | ™™™™™™error:
  2249 | ™™™™™™–W'&÷" –ç7F æ6Vöb W'&÷" ò W'&÷"æÖW76 vR ¢ 7G&–ær†W'&÷"’À
> 2250 | ™™™™™™message: "Failed to delete variable",
  2251 | ™™™™™™hint: "Make sure the Desktop Bridge plugin is running and the variable ID is correct",
  2252 | ™™™™™–ÒÀ
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#189 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:2262`

High-risk permission pattern: // Tool: Delete a variable collection

```
  2260 | ™);
  2261 |
> 2262 | ™// Tool: Delete a variable collection
  2263 | ™this.server.tool(
  2264 | ™’&f–vÖ öFVÆWFU÷f &– &ÆUö6öÆÆV7F–öâ"À
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#190 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:2265`

High-risk permission pattern: "Delete a Figma variable collection and ALL its variables. WARNING: This is a de

```
  2263 | ™this.server.tool(
  2264 | ™’&f–vÖ öFVÆWFU÷f &– &ÆUö6öÆÆV7F–öâ"À
> 2265 | ™’$FVÆWFR   f–vÖ  f &– &ÆR 6öÆÆV7F–öâ  æB  ÄÂ —G2 f &– &ÆW2â t $ä”äs¢ F†—2 —2   FW7G'V7F—fR ÷ W& F–öâ
that deletes all variables in the collection and cannot be undone (except with Figma's undo). Requires the
Desktop Bridge plugin to be running.",
  2266 | ™—› P
  2267 | ™™™collectionId: z
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#191 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:2270`

High-risk permission pattern: "The collection ID to delete (e.g., 'VariableCollectionId:123:456'). Get this fr

```
  2268 | ™™™’ç7G&–ær,•
  2269 | ™™™’æFW67&–&R€
> 2270 | ™™™™"The collection ID to delete (e.g., 'VariableCollectionId:123:456'). Get this from
figma_get_variables.",
  2271 | ™™™’’À
  2272 | ™—ÒÀ
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#192 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:2296`

High-risk permission pattern: logger.error({ error }, "Failed to delete collection");

```
  2294 | ™™™—Ó°
  2295 | ™™™} catch (error) {
> 2296 | ™™™—ÆövvW"æW'&÷"‡² W'&÷" ÒÂ $f –ÆVB Fò FVÆWFR 6öÆÆV7F–öâ"”°
  2297 | ™™™—&WGW&â °
  2298 | ™™™™content: [
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#193 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:2305`

High-risk permission pattern: message: "Failed to delete variable collection",

```
  2303 | ™™™™™error:
  2304 | ™™™™™–W'&÷" –ç7F æ6Vöb W'&÷" ò W'&÷"æÖW76 vR ¢ 7G&–ær†W'&÷"'À
> 2305 | ™™™™™message: "Failed to delete variable collection",
  2306 | ™™™™™hint: "Make sure the Desktop Bridge plugin is running and the collection ID is correct",…
  2307 | ™™™™™—ÒÀ
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#194 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:2506`

High-risk permission pattern: // Execute multiple variable operations in a single roundtrip,

```
  2504 | ™// BATCH OPERATIONS (Performance-Optimized)
  2505 | ™// ==========================================================================
> 2506 | ™// Execute multiple variable operations in a single roundtrip,
  2507 | ™// reducing per-operation overhead from ~60-170ms to near-zero.
  2508 | ™// Use these instead of calling individual tools repeatedly.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#195 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:4487`

High-risk permission pattern: // Tool: Delete Component Property

```
  4485 | ™);
  4486 |
> 4487 | ™// Tool: Delete Component Property
  4488 | ™this.server.tool(
  4489 | ™'&f–vÖ öFVÆWFUö6ö× öæVçE÷ &÷ W'G'"À
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#196 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:4490`

High-risk permission pattern: "Delete a component property. Only works with BOOLEAN, TEXT, and INSTANCE_SWAP p

```
  4488 | ™this.server.tool(
  4489 | ™'&f–vÖ öFVÆWFUö6ö× öæVçE÷ &÷ W'G'"À
> 4490 | ™'$FVÆWFR   6ö× öæVçB  &÷ W'G'â öæÇ' v÷&·2 v—F, $ôôÄT âÂ DU…BÂ  æB "å5D ä4Uõ5t    &÷ W'F–W2 †æ÷B
VARIANT). This is a destructive operation.",
  4491 | ™—°
  4492 | ™™nodeId: z.string().describe("The component or component set node ID"),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#197 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:4508`

High-risk permission pattern: throw new Error(result.error || "Failed to delete property");

```
  4506 |
  4507 | ™™™–-b , &W7VÇBç7V66W72’ °
> 4508 | ™™™™throw new Error(result.error || "Failed to delete property");
  4509 | ™™™–ØP
  4510 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#198 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:4525`

High-risk permission pattern: logger.error({ error }, "Failed to delete component property");

```
  4523 | ™™™–Ó°
  4524 | ™™™} catch (error) {
> 4525 | ™™™–ÆövvW"æW'&÷"‡² W'&÷" ÒÂ $f –ÆVB Fò FVÆWFR 6ö× öæVçB  &÷ W'G’"“°
  4526 | ™™™–&WGW&â °
  4527 | ™™™™content: [
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#199 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:4534`

High-risk permission pattern: hint: "Cannot delete VARIANT properties. Only BOOLEAN, TEXT, and INSTANCE_SWAP c

```
  4532 | ™™™™™™error:
  4533 | ™™™™™™–W'&÷" –ç7F æ6Vöb W'&÷" ò W'&÷"æÖW76 vR ¢ 7G&–ær†W'&÷"’À
> 4534 | ™™™™™™hint: "Cannot delete VARIANT properties. Only BOOLEAN, TEXT, and INSTANCE_SWAP can be deleted.",
  4535 | ™™™™™–ÒÀ
  4536 | ™™™™™),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#200 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:4909`

High-risk permission pattern: // Tool: Delete Node

```
  4907 | ™);
  4908 |
> 4909 | ™// Tool: Delete Node
  4910 | ™this.server.tool(…
  4911 | ™’&f–vÖ öFVÆWFUöæöFR"À
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#201 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:4912`

High-risk permission pattern: "Delete a node from the canvas. WARNING: This is a destructive operation (can be

```
  4910 | ™this.server.tool(
  4911 | ™’&f–vÖ öFVÆWFUöæöFR"À
> 4912 | ™’$FVÆWFR   æöFR g&öÒ F†R 6 çf 2â t $ä”äs¢ F†–2 –2   FW7G'V7F–fR ÷ W& F–öâ †6 â &R VæFöæR v–F, f–vÖ w2
undo).",
  4913 | ™–°
  4914 | ™™nodeId: z.string().describe("The node ID to delete"),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#202 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:4914`

High-risk permission pattern: nodeId: z.string().describe("The node ID to delete"),

```
  4912 | ™’$FVÆWFR   æöFR g&öÒ F†R 6 çf 2â t $ä”äs¢ F†–2 –2   FW7G'V7F–fR ÷ W& F–öâ †6 â &R VæFöæR v–F, f–vÖ w2
undo).",
  4913 | ™–°
> 4914 | ™™nodeId: z.string().describe("The node ID to delete"),
  4915 | ™–ÒÀ
  4916 | ™– 7–æ2 ‡² æöFT–B Ò’ Óâ °
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#203 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:4922`

High-risk permission pattern: throw new Error(result.error || "Failed to delete node");

```
  4920 |
  4921 | ™™––b , &W7VÇBç7V66W72’ °
> 4922 | ™™™throw new Error(result.error || "Failed to delete node");
  4923 | ™™–Ð
  4924 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#204 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:4940`

High-risk permission pattern: logger.error({ error }, "Failed to delete node");

```
  4938 | ™™—Ó°
  4939 | ™™} catch (error) {
> 4940 | ™™–ÆövvW"æW'&÷"‡² W'&÷" ÒÂ $f –ÆVB Fò FVÆWFR æöFR"“°
  4941 | ™™—&WGW&â ¸P
  4942 | ™™™content: [
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#205 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:5196`

High-risk permission pattern: // Build the code to execute in Figma

```
  5194 | ™™–6öç7B 6öææV7F÷" Ò  v —B F†—2ævWDFW6·F÷ 6öææV7F÷",“°
  5195 |
> 5196 | ™™′òò 'V–ÆB F†R 6öFR Fò W†V7WFR –â f–vÖ
  5197 | ™™–6öç7B 6öFR Ò
  5198 | // ==========================================================================
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#206 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:5344`

High-risk permission pattern: // Delete the old component set

```
  5342 | }
  5343 |
> 5344 | // Delete the old component set
  5345 | componentSet.remove();
  5346 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#207 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`src/local.ts:6240`

High-risk permission pattern: this.variablesCache.delete(data.fileKey);

```
  6238 | ™™™if (data.fileKey) {
  6239 | ™™™’òò  W"Öf–ÆR 6 6†R –çf Æ–F F–öâ r öæÇ’ 6ÆV " F†R  ffV7FVB f–ÆRw2 6 6†P
> 6240 | ™™™—F†—2çf &– &ÆW46 6†RæFVÆWFR†F F æf–ÆT¶W’“°
  6241 | ™™™} else {…
  6242 | ™™™—F†—2çf &– &ÆW46 6†Ræ6ÆV ",“°
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#208 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`src/test-browser.ts:6`

Dependency without integrity verification

```
     4 |  */
     5 |
>    6 | import puppeteer from '@cloudflare/puppeteer';
     7 | import type { Env } from './browser-manager.js';
     8 |
```

Remediation:
1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#209 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/test-browser.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Test script to verify Browser Rendering API access
     3 |  * Run with: npx wrangler dev and visit /test-browser
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#210 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/__mocks__/cloudflare-workers.js:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Mock for cloudflare:workers module used in Jest tests.
     3 |  * Provides a minimal DurableObject base class so cloud-only
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#211 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/basic.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | describe('Basic MCP Server Test', () => {
     2 |   it('should pass basic test', () => {…
     3 |     expect(true).toBe(true);
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#212 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/comment-tools.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Comment Tools Tests
     3 |  *
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#213 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/design-code-tools.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | import {
     2 | –f–vÖ $t$ Fô†W,À
     3 | –æ÷&Ö Æ—¦T6öÆ÷"À
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#214 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/design-system-tools.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Design System Kit Tool Tests
     3 |  *
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#215 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/file-url-fallback.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * File URL Fallback Tests…
     3 |  *
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#216 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/library-components.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Library Component Access Tests
     3 |  *
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#217 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/lint-design.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Tests for figma_lint_design tool
     3 |  *
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#218 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/port-discovery.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Tests for the port discovery module.
     3 |  * Covers: port range generation, port file lifecycle, PID validation,
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#219 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`tests/schema-compatibility.test.ts:239`

Potential secret: possible hardcoded secret

```
  237 | ™});
  238 |
> 239 | ™describe("addComponentPropertyDefaultValue", () => {
  240 | ™––B,'6†÷VÆB  66W B 7G&–ær f ÇVW2"Â ,’ Óâ ¸P
  241 | ™™expect(() => schemas.addComponentPropertyDefaultValue.parse("Default Text")).not.toThrow();
```

Remediation:
1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#220 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`tests/schema-compatibility.test.ts:382`

Potential secret: possible hardcoded secret

```
  380 | ™™{ name: "createVariableValuesByMode", schema: schemas.createVariableValuesByMode },
  381 | ™™{ name: "instantiateComponentOverrides", schema: schemas.instantiateComponentOverrides },
> 382 | ™™{ name: "addComponentPropertyDefaultValue", schema: schemas.addComponentPropertyDefaultValue },
  383 | ™™{ name: "editComponentPropertyNewValue", schema: schemas.editComponentPropertyNewValue },
  384 | ™•Ó°
```

Remediation:
1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#221 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`tests/schema-compatibility.test.ts:399`

Potential secret: possible hardcoded secret

```
  397 | ™–6öç7B Væ–öå66†VÖ 2 Ò °
  398 | ™™{ name: "updateVariableValue", schema: schemas.updateVariableValue },
> 399 | ™™{ name: "addComponentPropertyDefaultValue", schema: schemas.addComponentPropertyDefaultValue },
  400 | ™•Ó°
  401 |
```

Remediation:
1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#222 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/schema-compatibility.test.ts:1`

No logging, auditing, or monitoring detected

```
>   1 | import { z } from "zod";
    2 | import { zodToJsonSchema } from "zod-to-json-schema";
    3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#223 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/scoring/component-classification.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Component Classification Tests…
     3 |  *
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#224 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/scoring/end-to-end.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * End-to-End Scoring Pipeline Test
     3 |  *
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#225 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/scoring/scoring-engine.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Scoring Engine Tests
     3 |  *
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#226 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/scoring/ui-rendering.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * UI Rendering Logic Tests
     3 |  *
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#227 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`tests/set-image-fill.test.ts:228`

Dangerous execution: // function(params) { return window.setImageFill(params.nodeIds || params.nodeId

```
   226 | ™it('should map SET_IMAGE_FILL to window.setImageFill', () => {
   227 | ™’òò F†R ÖWF†öB Ö   –â V’æ‡FÖÂ &÷WFW2 u4UEõ”Ô tUôd”ÂÂr Fó
>  228 | ™’òò gVæ7F–öâ‡  & ×2’ ² &WGW&â v–æF÷rç6WD–Ö vTf–ÆÂ‡  & ×2ææöFT–G2 ÇÂ   & ×2ææöFT–BÂ   & ×2æ–Ö vTF F Â
params.scaleMode); }
   229 | ™–6öç7B   & ×2 Ò ˙P
   230 | ™™nodeIds: ['1:2', '3:4'],
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#228 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/set-image-fill.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Tests for figma_set_image_fill tool
     3 |  *
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#229 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`vite.config.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | import { resolve } from "node:path";
     2 | import { defineConfig } from "vite";
     3 | import { viteSingleFile } from "vite-plugin-singlefile";
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#230 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`worker-configuration.d.ts:2210`

Dangerous execution: exec(input?: (string | URLPatternURLPatternInit), baseURL?: string): URLPatternU

```
  2208 |     get hash(): string;
  2209 |     test(input?: (string | URLPatternURLPatternInit), baseURL?: string): boolean;
> 2210 |     exec(input?: (string | URLPatternURLPatternInit), baseURL?: string): URLPatternURLPatternResult
| null;
  2211 | }
  2212 | interface URLPatternURLPatternInit {
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#231 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`worker-configuration.d.ts:4641`

Dangerous execution: exec(query: string): Promise<D1ExecResult>;

```
  4639 |     prepare(query: string): D1PreparedStatement;
  4640 |     batch<T = unknown>(statements: D1PreparedStatement[]): Promise<D1Result<T>[]>;
> 4641 |     exec(query: string): Promise<D1ExecResult>;
  4642 |     /**…
  4643 |      * Creates a new D1 Session anchored at the given constraint or the bookmark.
```

Remediation:
1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#232 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`worker-configuration.d.ts:4368`

Potential secret: possible hardcoded secret

```
  4366 |      * The client's [`HELLO` message](https://www.rfc-editor.org/rfc/rfc5246#section-7.4.1.2),
encoded in hexadecimal
  4367 |      *
> 4368 |      * @example "44372ba35fa1270921d318f34c12f155dc87b682cf36a790cfaa3ba8737a1b5d"
  4369 |      */
  4370 |     clientHandshake: string;
```

Remediation:
1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#233 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`worker-configuration.d.ts:4374`

Potential secret: possible hardcoded secret

```
  4372 |      * The server's [`HELLO` message](https://www.rfc-editor.org/rfc/rfc5246#section-7.4.1.2),
encoded in hexadecimal
  4373 |      *
> 4374 |      * @example "44372ba35fa1270921d318f34c12f155dc87b682cf36a790cfaa3ba8737a1b5d"
  4375 |      */
  4376 |     serverHandshake: string;
```

Remediation:
1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#234 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`worker-configuration.d.ts:4380`

Potential secret: possible hardcoded secret

```
  4378 |      * The client's [`FINISHED` message](https://www.rfc-editor.org/rfc/rfc5246#section-7.4.9),
encoded in hexadecimal
  4379 |      *
> 4380 |      * @example "084ee802fe1348f688220e2a6040a05b2199a761f33cf753abb1b006792d3f8b"
  4381 |      */…
  4382 |     clientFinished: string;
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#235 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`worker-configuration.d.ts:4386`

Potential secret: possible hardcoded secret

```
  4384 |      * The server's [`FINISHED` message](https://www.rfc-editor.org/rfc/rfc5246#section-7.4.9),
encoded in hexadecimal
  4385 |      *
> 4386 |      * @example "084ee802fe1348f688220e2a6040a05b2199a761f33cf753abb1b006792d3f8b"
  4387 |      */
  4388 |     serverFinished: string;
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#236 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`worker-configuration.d.ts:4540`

Potential secret: possible hardcoded secret

```
  4538 |      * The certificate's SHA-1 fingerprint
  4539 |      *
> 4540 |      * @example "6b9109f323999e52259cda7373ff0b4d26bd232e"
  4541 |      */
  4542 |     certFingerprintSHA1: string;
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#237 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`worker-configuration.d.ts:4546`

Potential secret: possible hardcoded secret

```
  4544 |      * The certificate's SHA-256 fingerprint
  4545 |      *
> 4546 |      * @example "acf77cf37b4156a2708e34c4eb755f9b5dbbe5ebb55adfec8f11493438d19e6ad3f157f81fa3b9827845
3d5652b0c1fd1d71e5695ae4d709803a4d3f39de9dea"
  4547 |      */
  4548 |     certFingerprintSHA256: string;
```

Remediation:
1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#238 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:461`

High-risk permission pattern: delete(key: string, options?: DurableObjectPutOptions): Promise<boolean>;

```
   459 |     put<T>(key: string, value: T, options?: DurableObjectPutOptions): Promise<void>;
   460 |     put<T>(entries: Record<string, T>, options?: DurableObjectPutOptions): Promise<void>;
>  461 |     delete(key: string, options?: DurableObjectPutOptions): Promise<boolean>;
   462 |     delete(keys: string[], options?: DurableObjectPutOptions): Promise<number>;…
   463 |     rollback(): void;
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#239 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:462`

High-risk permission pattern: delete(keys: string[], options?: DurableObjectPutOptions): Promise<number>;

```
   460 |     put<T>(entries: Record<string, T>, options?: DurableObjectPutOptions): Promise<void>;
   461 |     delete(key: string, options?: DurableObjectPutOptions): Promise<boolean>;
>  462 |     delete(keys: string[], options?: DurableObjectPutOptions): Promise<number>;
   463 |     rollback(): void;
   464 |     getAlarm(options?: DurableObjectGetAlarmOptions): Promise<number | null>;
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#240 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:474`

High-risk permission pattern: delete(key: string, options?: DurableObjectPutOptions): Promise<boolean>;

```
   472 |     put<T>(key: string, value: T, options?: DurableObjectPutOptions): Promise<void>;
   473 |     put<T>(entries: Record<string, T>, options?: DurableObjectPutOptions): Promise<void>;
>  474 |     delete(key: string, options?: DurableObjectPutOptions): Promise<boolean>;
   475 |     delete(keys: string[], options?: DurableObjectPutOptions): Promise<number>;
   476 |     deleteAll(options?: DurableObjectPutOptions): Promise<void>;
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#241 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:475`

High-risk permission pattern: delete(keys: string[], options?: DurableObjectPutOptions): Promise<number>;

```
   473 |     put<T>(entries: Record<string, T>, options?: DurableObjectPutOptions): Promise<void>;
   474 |     delete(key: string, options?: DurableObjectPutOptions): Promise<boolean>;
>  475 |     delete(keys: string[], options?: DurableObjectPutOptions): Promise<number>;
   476 |     deleteAll(options?: DurableObjectPutOptions): Promise<void>;…
   477 |     transaction<T>(closure: (txn: DurableObjectTransaction) => Promise<T>): Promise<T>;
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#242 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:841`

High-risk permission pattern: /* [Cloudflare Docs Reference](https://developers.cloudflare.com/workers/runtime

```
   839 | */
   840 | declare abstract class Cache {
>  841 |     /* [Cloudflare Docs Reference](https://developers.cloudflare.com/workers/runtime-apis/cache/
#delete) */
   842 |     delete(request: RequestInfo | URL, options?: CacheQueryOptions): Promise<boolean>;
   843 |     /* [Cloudflare Docs Reference](https://developers.cloudflare.com/workers/runtime-apis/cache/
#match) */
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#243 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:842`

High-risk permission pattern: delete(request: RequestInfo | URL, options?: CacheQueryOptions): Promise<boolean

```
   840 | declare abstract class Cache {
   841 |     /* [Cloudflare Docs Reference](https://developers.cloudflare.com/workers/runtime-apis/cache/
#delete) */
>  842 |     delete(request: RequestInfo | URL, options?: CacheQueryOptions): Promise<boolean>;
   843 |     /* [Cloudflare Docs Reference](https://developers.cloudflare.com/workers/runtime-apis/cache/
#match) */
   844 |     match(request: RequestInfo | URL, options?: CacheQueryOptions): Promise<Response | undefined>;
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#244 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:1118`

High-risk permission pattern: /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/FormData/delete) *

```
  1116 |     /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/FormData/append) */
  1117 |     append(name: string, value: Blob, filename?: string): void;
> 1118 |     /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/FormData/delete) */
  1119 |     delete(name: string): void;
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#245 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:1119`

High-risk permission pattern: delete(name: string): void;

```
  1117 |     append(name: string, value: Blob, filename?: string): void;
  1118 |     /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/FormData/delete) */
> 1119 |     delete(name: string): void;
  1120 |     /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/FormData/get) */
  1121 |     get(name: string): (File | string) | null;
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#246 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:1246`

High-risk permission pattern: /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/Headers/delete) */

```
  1244 |     /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/Headers/append) */
  1245 |     append(name: string, value: string): void;
> 1246 |     /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/Headers/delete) */
  1247 |     delete(name: string): void;
  1248 |     forEach<This = unknown>(callback: (this: This, value: string, key: string, parent: Headers) =>
void, thisArg?: This): void;
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#247 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:1247`

High-risk permission pattern: delete(name: string): void;

```
  1245 |     append(name: string, value: string): void;
  1246 |     /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/Headers/delete) */
> 1247 |     delete(name: string): void;
  1248 |     forEach<This = unknown>(callback: (this: This, value: string, key: string, parent: Headers) =>
void, thisArg?: This): void;
  1249 |     /* Returns an iterator allowing to go through all key/value pairs contained in this object. */
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#248 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:1451`

High-risk permission pattern: delete(key: Key): Promise<void>;

```
  1449 |     getWithMetadata<Metadata = unknown>(key: Key, options: KVNamespaceGetOptions<"arrayBuffer">):
Promise<KVNamespaceGetWithMetadataResult<ArrayBuffer, Metadata>>;
  1450 |     getWithMetadata<Metadata = unknown>(key: Key, options: KVNamespaceGetOptions<"stream">):
Promise<KVNamespaceGetWithMetadataResult<ReadableStream, Metadata>>;
> 1451 |     delete(key: Key): Promise<void>;
  1452 | }…
  1453 | interface KVNamespaceListOptions {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#249 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:1539`

High-risk permission pattern: delete(keys: string | string[]): Promise<void>;

```
  1537 |     createMultipartUpload(key: string, options?: R2MultipartOptions): Promise<R2MultipartUpload>;
  1538 |     resumeMultipartUpload(key: string, uploadId: string): R2MultipartUpload;
> 1539 |     delete(keys: string | string[]): Promise<void>;
  1540 |     list(options?: R2ListOptions): Promise<R2Objects>;
  1541 | }
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#250 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:2153`

High-risk permission pattern: * [MDN Reference](https://developer.mozilla.org/docs/Web/API/URLSearchParams/del

```
  2151 |      * Deletes the given search parameter, and its associated value, from the list of all search
parameters.
  2152 |      *
> 2153 |      * [MDN Reference](https://developer.mozilla.org/docs/Web/API/URLSearchParams/delete)
  2154 |      */
  2155 |     delete(name: string, value?: string): void;
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#251 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:2155`

High-risk permission pattern: delete(name: string, value?: string): void;

```
  2153 |      * [MDN Reference](https://developer.mozilla.org/docs/Web/API/URLSearchParams/delete)
  2154 |      */
> 2155 |     delete(name: string, value?: string): void;
  2156 |     /**
  2157 |      * Returns the first value associated to the given search parameter.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#252 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:2175`

High-risk permission pattern: * Sets the value associated to a given search parameter to the given value. If t

```
  2173 |     has(name: string, value?: string): boolean;
  2174 |     /**
> 2175 |      * Sets the value associated to a given search parameter to the given value. If there were
several values, delete the others.
  2176 |      *…
  2177 |      * [MDN Reference](https://developer.mozilla.org/docs/Web/API/URLSearchParams/set)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#253 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:5526`

High-risk permission pattern: * Delete a list of vectors with a matching id.

```
  5524 |     public upsert(vectors: VectorizeVector[]): Promise<VectorizeVectorMutation>;
  5525 |     /**
> 5526 |      * Delete a list of vectors with a matching id.
  5527 |      * @param ids List of vector ids that should be deleted.
  5528 |      * @returns A promise that resolves with the ids & count of records that were successfully
processed (and thus deleted).
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#254 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:5576`

High-risk permission pattern: * Delete a list of vectors with a matching id.

```
  5574 |     public upsert(vectors: VectorizeVector[]): Promise<VectorizeAsyncMutation>;
  5575 |     /**
> 5576 |      * Delete a list of vectors with a matching id.
  5577 |      * @param ids List of vector ids that should be deleted.
  5578 |      * @returns A promise that resolves with a unique identifier of a mutation containing the delete
changeset.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#255 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`worker-configuration.d.ts:5578`

High-risk permission pattern: * @returns A promise that resolves with a unique identifier of a mutation contai

```
  5576 |      * Delete a list of vectors with a matching id.
  5577 |      * @param ids List of vector ids that should be deleted.
> 5578 |      * @returns A promise that resolves with a unique identifier of a mutation containing the delete
changeset.
  5579 |      */…
  5580 |     public deleteByIds(ids: string[]): Promise<VectorizeAsyncMutation>;
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#256 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`worker-configuration.d.ts:832`

File input near prompt/instruction handling — injection vector

```
   830 | declare abstract class CacheStorage {
   831 |     /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/CacheStorage/open) */
>  832 |     open(cacheName: string): Promise<Cache>;
   833 |     readonly default: Cache;
   834 | }
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#257 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`worker-configuration.d.ts:2907`

File input near prompt/instruction handling — injection vector

```
  2905 |     get readyState(): number;
  2906 |     /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/EventSource/open_event) */
> 2907 |     get onopen(): any | null;
  2908 |     /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/EventSource/open_event) */
  2909 |     set onopen(value: any | null);
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#258 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`worker-configuration.d.ts:2909`

File input near prompt/instruction handling — injection vector

```
  2907 |     get onopen(): any | null;
  2908 |     /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/EventSource/open_event) */
> 2909 |     set onopen(value: any | null);
  2910 |     /* [MDN Reference](https://developer.mozilla.org/docs/Web/API/EventSource/message_event) */
  2911 |     get onmessage(): any | null;
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

Remediation Checklist

Prioritized by severity. Address CRITICAL items first.

Quick Win `npm install mcp-secure`

Adds cryptographic passports, signed messages, tool verification, and audit logging.

CRITICAL (2)

- [ ] **AS-001: unsafe execution**
  Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code).
- [ ] **AS-005: injection pattern**
  Validate and sanitize all inputs with strict allowlists.

HIGH (3)

- [ ] **AS-002: secret scan**
  Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv).
- [ ] **AS-006: sandboxing**
  Run all agent-generated code in Docker containers with --network=none and read-only filesystem.
- [ ] **AS-004: prompt injection**
  Sanitize all file contents before injecting into prompts (strip control chars, limit length).

MEDIUM (3)

- [ ] **AS-003: excessive permissions**
  Apply principle of least privilege — grant only permissions the agent needs for its specific task.
- [ ] **AS-010: logging monitoring**
  Add structured logging (JSON) for every agent action, tool call, and decision.
- [ ] **AS-009: output handling**
  Always use textContent instead of innerHTML for agent-generated text.

LOW (1)

- [ ] **AS-007: supply chain**
  Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes).

Methodology & Standards

Scanner	**mcps-audit v1.0.0**
Rules Version	**1.1.0**
Scanned At	**20/03/2026, 21:01:34**
Report ID	**MCPS-MMYYWI4J**

Referenced Standards

OWASP MCP Top 10
Security risks for Model Context Protocol servers and clients.
owasp.org/www-project-mcp-top-10

OWASP Agentic AI Top 10
Security risks for autonomous AI agents.
owasp.org/www-project-agentic-ai-top-10

MCPS -- IETF Internet-Draft
Cryptographic security layer for MCP: draft-sharif-mcps-secure-mcp.
datatracker.ietf.org/doc/draft-sharif-mcps-secure-mcp

MITRE ATT&CK
Adversary tactics and techniques knowledge base.
attack.mitre.org

STRIDE Threat Model
Microsoft threat classification framework.
microsoft.com/en-us/security/blog/stride

AgentSign
Cryptographic identity and security for AI agents
agentsign.dev